Dokumen kebutuhan produk KAPDH Apps

Versi 3.5 | 12 Oktober 2026 | Status disahkan pemilik produk untuk memulai Tahap 0

Pemilik produk: Bayu Musthafa. Pembaca: pengurus KAPDH, tim produk, pengembang Flutter dan web admin, backend engineer, QA, serta pengelola infrastruktur.

Dokumen ini menetapkan kebutuhan aplikasi keanggotaan alumni KAPDH, portal pengurus, dan situs publik, termasuk aturan iuran, KTA, event, komunikasi, keamanan, dan operasi layanan pada VPS sendiri.

KAPDH Apps dibangun sebagai **pengembangan baru (greenfield)**. Tidak ada sistem produksi, data, akun, maupun aplikasi klien lama yang harus dipertahankan atau dimigrasikan. Supabase dan Vercel tidak dipakai pada tahap apa pun.

Rilis lengkap pertama tetap mencakup seluruh kebutuhan F-01 sampai F-17. Kebutuhan yang diberi label Usulan belum disahkan; nilai yang disahkan pemilik produk ditandai *disahkan v3.2* sampai *v3.5*; keputusan yang masih terbuka dicatat dalam register D1 sampai D16.

PRD ini menjadi acuan perilaku produk dan penerimaan rilis. Detail kontrak API dan desain database harus mengikuti aturan bisnisnya. Target operasional merupakan sasaran yang harus diuji, bukan hasil pengujian yang telah dicapai.

Ringkasan perubahan versi 3.5

Versi ini menutup keputusan produk yang tersisa sehingga Tahap 0 dapat dimulai. Keputusan teknis rinci (TTL refresh, rate limit final, provider email, versi patch) tetap dikunci pengembang pada Tahap 0 dalam batas yang ditetapkan di sini. Perubahan versi sebelumnya dicatat pada riwayat versi 11.3.

Keputusan	Isi yang disahkan pada v3.5
D1 Super Admin	Super Admin pertama: Bayu Musthafa (pemilik produk). Super Admin kedua ditunjuk sebelum go-live.
D12 Domain	kapdh.or.id untuk situs publik, admin.kapdh.or.id untuk web admin, api.kapdh.or.id untuk API; staging memakai subdomain terpisah.
D13 Kanal bayar	Iuran dan tiket dibayar melalui kanal sendiri (transfer manual) sebagai iuran organisasi dan layanan di luar aplikasi, dengan mitigasi risiko review Apple.
D5 Event	Reservasi ditahan 24 jam menunggu bukti; check-in dibuka 2 jam sebelum acara sampai acara selesai.
D6 Refund	Aturan pembatalan dan refund manual ditetapkan pada 3.9.
D7 Kapasitas	VPS awal 4 vCPU, RAM 8 GB, disk 100 GB di Jakarta atau Singapura; Android 8.0+, iOS 15+, dua versi terakhir browser utama.
D9 Operasi	Akses root dan Coolify oleh pemilik produk dan satu cadangan; backup harian terenkripsi ke object storage di luar VPS; alert melalui Uptime Kuma; uji restore bulanan.
D10 Layanan eksternal	Email dari noreply@kapdh.or.id dengan SPF/DKIM/DMARC; FCM/APNs untuk push; akun Apple Developer dan Google Play atas nama organisasi dengan D-U-N-S.
D16 Go-live	Target setelah Idulfitri 2027 (akhir Maret sampai April 2027), uji terbatas 2 sampai 3 minggu, rilis bertahap, akun demo reviewer.

Daftar isi

Gunakan daftar ini untuk membuka bagian terkait. ID fitur dan kriteria penerimaan menjadi acuan tugas serta pengujian.

1 Gambaran produk 3

2 Persyaratan umum 6

3 Kebutuhan fungsional 10

4 Alur pengguna dan siklus status 20

5 Arsitektur dan operasi 24

6 Rancangan domain dan database 27

7 Stack teknologi dan struktur pekerjaan 30

8 Rencana pembangunan dan go-live 32

9 Pengujian dan penerimaan rilis 34

10 Keputusan terbuka dan risiko 36

11 Lampiran dan rujukan 39

Bagian 3 memuat 87 acceptance criteria untuk F-01 sampai F-17. Bagian 9 menetapkan bukti pengujian dan gerbang rilis; bagian 10 memuat keputusan yang harus ditutup sebelum tahap terkait.

1 Gambaran produk

1.1 Masalah dan hasil yang diharapkan

Pendaftaran, iuran, informasi organisasi, kegiatan, dan komunikasi alumni perlu terhubung pada satu identitas keanggotaan. Anggota harus dapat mengetahui status pembayaran dan masa aktif KTA. Pengurus harus dapat memproses antrean, mengendalikan akses, dan menelusuri keputusan tanpa mengandalkan pesan pribadi.

KAPDH Apps dibangun dari awal. Backend, database, dan hosting web berjalan di VPS yang dikelola melalui Coolify sejak rilis pertama. Tidak ada data, akun, transaksi, atau aplikasi klien sebelumnya yang harus dipindahkan atau dijaga kompatibilitasnya. Jumlah pengguna awal belum diketahui; kapasitas dan target diukur melalui uji beban (N-04) dan baseline 30 hari setelah go-live.

1.2 Tujuan produk

- Menghasilkan alur daftar, verifikasi email, pembayaran, persetujuan, dan penerbitan KTA yang dapat ditelusuri.
- Menegakkan masa aktif keanggotaan serta akses terbatas setelah kedaluwarsa atau suspend.
- Menyatukan berita, kegiatan, tiket, direktori, chat, dan notifikasi dengan identitas anggota.
- Memberikan pengurus portal operasional dengan izin per tindakan, MFA, dan audit.
- Menjalankan layanan inti pada VPS sendiri serta memulihkan layanan dari backup di luar VPS.
- Tidak mengumpulkan NIK, membatasi paparan data profil, dan menyediakan penghapusan akun.

1.3 Ketentuan pemilik dan batas produk

Backend menggunakan VPS dan PostgreSQL sendiri. Supabase, Vercel, maupun backend-as-a-service lain tidak dipakai sebagai database, autentikasi, hosting, atau ketergantungan runtime. Berkas menggunakan disk VPS terlebih dahulu dengan antarmuka StorageDriver untuk perpindahan ke S3-compatible. Aplikasi anggota hanya Flutter Android dan iOS; tidak ada aplikasi anggota berbasis web. Pengurus menggunakan web admin React. Deploy dan operasi menggunakan Coolify.

Ketentuan tanpa BaaS tidak menghilangkan layanan email, FCM, APNs, DNS, sertifikat TLS, maupun tujuan backup di luar VPS. Layanan tersebut tetap tercatat sebagai dependensi operasional. Firebase dipakai untuk push, bukan sebagai database atau autentikasi anggota.

Di luar R1.0: aplikasi anggota berbasis web atau PWA, migrasi atau impor massal data dari sistem lain, multi-organisasi, marketplace, dompet saldo, pembayaran berulang otomatis, payment gateway otomatis, panggilan suara/video, chat terenkripsi end-to-end, check-in offline, serta fitur AI. Refund pada R1.0 ditangani sebagai proses administratif tercatat; integrasi pengembalian dana otomatis tidak termasuk.

1.4 Pengguna dan kebutuhan utama

Peran	Kebutuhan	Kanal
Alumni baru	Daftar, verifikasi email, isi profil minimum, bayar iuran, pantau keputusan	Flutter
Anggota aktif	KTA, informasi, event, jejaring, chat, privasi dan preferensi	Flutter
Anggota kedaluwarsa	Melihat riwayat sendiri, memperpanjang, mengelola akun dan meminta penghapusan	Flutter

Peran	Kebutuhan	Kanal
Admin	Menjalankan tindakan sesuai izin pembayaran, anggota, konten, event atau moderasi	Web admin
Super Admin	Mengelola admin, izin dan kebijakan; menjaga kesinambungan akses pengurus	Web admin dengan akun terpisah dari alumni
Publik	Membaca informasi organisasi, memeriksa QR KTA, meminta penghapusan akun, mengunduh aplikasi	Situs publik

1.5 Cakupan rilis dan prioritas

P0, P1, dan P2 menyatakan urutan serta tingkat kritis pembangunan. Ketiganya termasuk rilis lengkap pertama R1.0. Milestone inti boleh dipakai untuk pengujian internal; publikasi sebagian fitur memerlukan perubahan cakupan yang disahkan pemilik produk.

Kelompok	ID	Urutan	Wajib R1.0
Auth, sesi, MFA dan berkas	F-01, F-02; dukungan seluruh modul	P0	Ya
Keanggotaan, iuran dan keputusan pembayaran	F-03, F-04, F-07	P1	Ya
KTA dan verifikasi publik	F-05, F-06	P1	Ya
Beranda, konten dan halaman	F-08, bagian F-15	P1	Ya
Notifikasi termasuk push	F-13	P1	Ya
Penghapusan akun	F-14	P1	Ya
Portal admin, izin dan audit	F-15, F-16, F-17	P1	Ya
Event, tiket dan check-in	F-09	P2	Ya
Direktori dan privasi profil	F-10	P2	Ya
Chat, blokir dan moderasi	F-11, F-12	P2	Ya

1.6 Metrik keberhasilan

Karena tidak ada data historis, baseline dihitung dari 30 hari pertama setelah go-live. Pengukuran menggunakan event backend dan agregat tanpa isi chat, bukti pembayaran, atau data kontak. Pengurus meninjau metrik setiap bulan. Target bertanda Usulan belum merupakan komitmen hasil bisnis.

Metrik	Definisi dan sumber	Sasaran awal
Konversi aktivasi	Akun dengan iuran registration paid dalam 7 hari dibagi akun baru dengan email terverifikasi pada cohort yang sudah berumur 7 hari	Baseline 30 hari pertama; target pertumbuhan disahkan D8
Waktu keputusan pembayaran	Selisih keputusan final pertama dan pengiriman bukti valid, median serta p95; pembayaran ulang dipisahkan	Usulan median 1 hari kerja; p95 2 hari kerja
Aktivitas anggota 30 hari	Anggota unik yang membuka konten, event, direktori atau chat dalam 30 hari; login dan background push dikecualikan	Baseline 30 hari pertama

Metrik	Definisi dan sumber	Sasaran awal
Pemanfaatan event	Kursi terkonfirmasi dan kursi check-in dibanding kuota event yang tidak dibatalkan	Dilaporkan per event
Keandalan keputusan	Pembayaran yang menghasilkan status, hak akses dan notifikasi konsisten dibanding semua keputusan	100 persen pada UAT; insiden production ditelusuri

2 Persyaratan umum

2.1 Sumber kebenaran dan waktu

API menjadi pintu akses seluruh klien. UI boleh membantu validasi dan routing, tetapi server selalu memeriksa identitas, izin, status keanggotaan, kepemilikan objek, serta keadaan terbaru. Constraint dan transaksi database menjaga nomor unik, uang, kuota, serta keputusan tunggal.

Timestamp disimpan dalam UTC menggunakan timestamptz. Pengguna melihat tanggal dalam Asia/Jakarta kecuali event menetapkan zona waktu lain. Periode 12 bulan menggunakan penambahan bulan kalender dari waktu aktivasi, bukan 365 hari. Keanggotaan berakhir saat now >= expires_at. Pada tanggal yang tidak tersedia di bulan tujuan, gunakan hari terakhir bulan tersebut dengan jam yang sama. Aturan tanggal diuji, termasuk 29 Februari.

2.2 Matriks akses berdasarkan status

Status akun users membatasi autentikasi. Status masa keanggotaan dihitung dari waktu berlaku. Suspend adalah lapisan moderasi yang mengalahkan masa aktif. Persetujuan pembayaran tidak pernah menghapus suspend. Hasil effective_status memakai label unverified, verified, expiring, expired, dan suspended sebagai kontrak bagi seluruh klien.

Keadaan	Akses yang diizinkan	Akses yang ditolak
pending_otp	Verifikasi/kirim ulang OTP, koreksi email melalui alur terverifikasi, bantuan dan informasi legal	Aplikasi utama, pembayaran dan KTA aktif
unverified	Profil minimum, KTA berlabel Tidak Aktif, instruksi iuran, pengiriman bukti, status/riwayat sendiri, pengaturan akun, legal, hapus akun	KTA aktif, pemesanan event, direktori, chat
verified atau expiring	Seluruh fitur anggota sesuai izin, preferensi dan privasi	Data privat pengguna lain dan fungsi pengurus tanpa izin
expired	Riwayat sendiri, kartu dengan label kedaluwarsa, perpanjangan, pengaturan akun, legal, hapus akun	Pemesanan baru, direktori, pengiriman chat dan fitur khusus anggota aktif
suspended	Portal pembatasan dengan alasan aman, bantuan, pemulihan akun dan penghapusan setelah verifikasi identitas	Aplikasi utama, KTA aktif, pembayaran baru dan tindakan komunitas
disabled atau deletion_pending	Pemulihan yang disetujui atau pemeriksaan status penghapusan dengan challenge terbatas	Sesi dan API anggota/admin biasa

Tiket yang telah paid sebelum anggota kedaluwarsa tetap dapat dilihat dan digunakan untuk check-in, selama akun tidak suspended/disabled dan event belum dibatalkan. Hak tersebut tidak membuka kembali chat atau direktori. Tiket anggota yang disuspend tidak berlaku; refund diputuskan pengurus per kasus (*disahkan v3.5*).

2.3 Hak akses pengurus

Menu yang tersembunyi tidak menggantikan pemeriksaan izin API. Akun admin dan akun alumni pribadi memakai identitas login terpisah. Izin memakai namespace tindakan, misalnya payments.read, payments.decide,

events.manage, events.checkin, moderation.resolve, audit.read, audit.export. Admin hanya memperoleh izin yang ditugaskan; penambahan izin setelah login berlaku melalui evaluasi server dan invalidasi sesi/versi izin.

Tindakan	Alumni	Admin dengan izin	Super Admin
Membaca profil dan riwayat sendiri	Ya	Akun alumni terpisah	Akun alumni terpisah
Membaca bukti dan memutus pembayaran	Tidak	payments.read dan payments.decide	Ya dengan audit
Mengubah profil anggota administratif	Tidak	members.manage; perubahan sensitif diaudit	Ya
Mengelola konten dan master	Tidak	content.manage atau master.manage	Ya
Mengelola event atau check-in	Tidak	events.manage atau events.checkin	Ya
Membaca bukti laporan dan moderasi	Laporan milik sendiri	moderation.read dan moderation.resolve	Ya
Menelusuri dan mengekspor audit	Tidak	audit.read dan audit.export	Ya
Mengubah metode bayar dan biaya	Tidak	settings.manage	Ya; reautentikasi untuk perubahan sensitif
Mengelola admin dan izin	Tidak	Tidak	Ya; MFA dan reautentikasi
Menginisiasi pemulihan sandi alumni	Pemulihan sendiri	Tidak	Ya; tidak melihat sandi

Pengurus tidak dapat menyetujui transaksi miliknya sendiri. Pemeriksaan konflik kepentingan menggunakan relasi identitas pengurus dan akun alumni yang ditetapkan saat provisioning, bukan hanya kesamaan user_id. Minimal dua pengurus dengan izin payments.decide wajib tersedia sebelum go-live agar pembayaran milik pengurus tetap dapat diproses (*disahkan v3.2*).

2.4 Target nonfungsional

Angka tambahan berikut adalah Usulan baseline untuk pengujian dan harus dikunci pada Tahap 0 melalui D7 dan D8. Kondisi uji menggunakan VPS sasaran, 100 sesi anggota, 5 sesi admin, dan data uji 5.000 profil serta 100.000 pesan. Unggah berkas, pengiriman email/push eksternal, dan cold start diukur terpisah.

ID	Target dan cara pembuktian
N-01 Kinerja API	p95 <= 500 ms untuk baca sederhana dan <= 1.000 ms untuk keputusan/reservasi pada 10 request per detik selama 15 menit; error tak terduga < 1 persen.
N-02 Realtime	p95 pesan yang telah committed tampil di penerima online <= 2 detik; reconnect mengambil pesan yang hilang tanpa duplikasi.
N-03 UX	p95 konten pertama dapat digunakan <= 3 detik pada profil jaringan uji 10 Mbps dan RTT 100 ms; loading, retry dan keadaan kosong tersedia.

ID	Target dan cara pembuktian
N-04 Kapasitas	Angka beban uji bukan prakiraan pengguna; naikkan kapasitas sebelum layanan gagal memenuhi N-01 atau N-02.
N-05 Availability	Usulan 99,5 persen per bulan untuk API publik dan auth, dari monitor eksternal; downtime deployment tetap dihitung.
N-06 Pemulihan	Backup DB dan berkas harian; RPO <= 24 jam dan RTO <= 4 jam dibuktikan lewat restore, bukan hanya keberhasilan backup.
N-07 Transport	HTTPS/WSS, TLS dan header keamanan; DB/Redis privat. HSTS diaktifkan setelah seluruh subdomain yang dicakup siap HTTPS.
N-08 Identitas	Access JWT 15 menit; refresh rotasi, deteksi reuse, pencabutan sesi; admin wajib MFA dan idle timeout 30 menit di server.
N-09 Data privat	Tidak ada NIK pada skema, payload, ekspor, log maupun backup. Setiap objek privat diperiksa kepemilikan dan izinnya.
N-10 Berkas	Gambar <= 5 MB, PDF <= 10 MB, magic bytes, decoding aman, EXIF gambar dibuang; maksimal 10 unggahan berhasil per jenis per rolling 24 jam.
N-11 Aksesibilitas	Web admin dapat dioperasikan dengan keyboard dan pembaca layar; Flutter memiliki label semantik, fokus jelas, serta uji pembesaran teks 200 persen pada alur kritis.
N-12 Platform	Android/iOS dan Chrome/Edge/Firefox/Safari desktop; versi OS minimum dan matriks perangkat dikunci D7 berdasarkan dependensi dan pengguna sasaran.
N-13 Kontrak	OpenAPI 3.1 terversi, error baku, SDK Dart/TypeScript; perubahan kontrak gagal CI bila memutus versi klien yang masih didukung.
N-14 Observabilitas	request_id/job_id menghubungkan log API, worker dan audit; tidak mencatat sandi, OTP, token, isi chat atau bukti pembayaran.
N-15 Privasi	Preferensi default melindungi kontak; penghapusan dapat dilanjutkan setelah gagal; retensi dan penggunaan data dijelaskan sebelum pengguna menyetujui.
N-16 Keamanan rilis	Lint, typecheck, unit/integrasi relevan, build dan uji akses objek harus lulus; tidak ada kerentanan kritis yang belum ditangani.

2.5 Baseline autentikasi dan unggahan

Sandi wajib berisi 8 sampai 72 byte UTF-8 dengan huruf besar, kecil, angka, dan simbol (*disahkan v3.2*). Batas 72 byte mengikuti batas input bcrypt. UI menampilkan batas byte dengan jelas (bukan jumlah karakter) dan server menolak, bukan memotong, input yang melampaui batas. Sandi di-hash dengan bcrypt memakai cost yang dikalibrasi terhadap VPS. Tidak ada OTP, sandi atau secret TOTP pada log.

OTP berisi 6 digit, berlaku 10 menit, maksimal 5 percobaan, dan kirim ulang paling cepat 60 detik. Pengiriman ulang membatalkan kode sebelumnya untuk tujuan yang sama. Kode disimpan sebagai hash/HMAC dengan secret server agar pencarian offline atas ruang 6 digit tidak mudah dilakukan. Challenge terikat akun, tujuan, dan challenge_id; keberhasilan hanya dapat dikonsumsi sekali secara atomik.

Usulan rate limit: maksimal 5 pengiriman OTP per jam per email, ditambah pembatasan IP; setelah 10 kegagalan login dalam 15 menit, terapkan cooldown 15 menit dengan jalur pemulihan yang tetap tersedia. Respons lupa sandi tidak mengungkap apakah email terdaftar. Nilai final disahkan D1 agar tidak menyebabkan penguncian akun oleh pihak lain.

Avatar, gambar chat, cover/banner, dan bukti pembayaran memiliki purpose serta izin yang berbeda. PDF hanya diperbolehkan untuk bukti pembayaran. Pemeriksaan server menolak ekstensi yang menyamarkan tipe, gambar dengan dimensi/decompression berlebihan, serta file yang gagal pemrosesan. Unggahan sementara yang tidak terkait objek dibersihkan lewat job; batas usia usulan 24 jam. Berkas privat tidak dilayani langsung dari folder publik.

3 Kebutuhan fungsional

Acceptance criteria menggunakan pola Diberikan, Ketika, Maka. Setiap aturan di bawah menjadi kontrak produk; perubahan nilai berlabel Usulan ditangani melalui register keputusan. Pengujian negatif hak akses berlaku pada seluruh fitur, bukan hanya pada layar admin.

3.1 Registrasi dan verifikasi email

F-01 | **P0** | **Cerita pengguna:** Sebagai alumni baru, saya ingin membuat akun dan memverifikasi email agar dapat melanjutkan pendaftaran keanggotaan.

Pendaftaran mengikuti stepper guidelines [R8]: Data Diri, OTP, Biaya KTA, Pembayaran. Langkah Data Diri mengumpulkan nama lengkap, jenis kelamin, email, sandi, angkatan, kelas masuk dan kelas keluar (misalnya Kelas 1 / 1 MTs sampai Kelas 6 / 3 Aliyah); tahun masuk, tahun keluar dan tahun lulus dihitung otomatis dari angkatan dan kelas sesuai aturan pada 3.5 (*disahkan v3.4*). Email dinormalisasi sebelum pemeriksaan unik. Akun baru berstatus pending_otp. Persetujuan privasi dan ketentuan dicatat beserta versi serta waktunya. Nomor KTP/NIK tidak diminta; field Nomor KTP pada mockup guidelines tidak dipakai (*disahkan v3.3*).

- **AC F01-1:** Diberikan email baru dan sandi valid, ketika registrasi dikirim, maka hanya satu akun pending_otp dibuat dan challenge OTP diproses tanpa menampilkan kode ke klien.
- **AC F01-2:** Diberikan OTP belum kedaluwarsa, ketika kode benar dikirim, maka akun menjadi active, email_verified_at terisi, nomor anggota dialokasikan dengan KTA berstatus Tidak Aktif, dan pengguna melanjutkan ke langkah Biaya KTA.
- **AC F01-3:** Diberikan kode salah 5 kali, kedaluwarsa, pernah dipakai, atau diganti oleh resend, ketika verifikasi dicoba, maka akses ditolak dan UI menawarkan alur challenge baru yang memenuhi cooldown.
- **AC F01-4:** Diberikan request ganda atau jaringan putus, ketika klien mengulang registrasi, maka tidak ada akun duplikat dan pengguna dapat melanjutkan verifikasi akun yang sama.

3.2 Login, pemulihan dan sesi

F-02 | **P0** | **Cerita pengguna:** Sebagai pengguna, saya ingin login dan memulihkan akun tanpa kehilangan kendali atas sesi perangkat.

Alumni masuk dengan email/sandi. Admin harus menyelesaikan TOTP sebelum memperoleh akses admin; sesi tahap sandi tidak boleh memakai API admin. Backup code sekali pakai tersedia untuk pemulihan MFA. JWT memuat identitas sesi, audience dan expiry; server memeriksa status/revocation untuk tindakan terlindungi.

- **AC F02-1:** Diberikan login alumni valid, ketika token diterbitkan, maka access token berlaku 15 menit dan profil effective_status menentukan rute serta izin.
- **AC F02-2:** Diberikan admin yang belum membuktikan TOTP, ketika endpoint admin dipanggil, maka ditolak walaupun sandi benar; tidak ada masa transisi aal1 di production.
- **AC F02-3:** Diberikan refresh token yang sudah dipakai, ketika dipakai kembali, maka keluarga sesi dicabut dan pengguna diminta login ulang; pergantian token dijalankan atomik.
- **AC F02-4:** Diberikan pemulihan OTP valid, ketika sandi baru disimpan, maka seluruh sesi dicabut dan OTP dikonsumsi; ganti sandi normal juga mensyaratkan sandi lama.
- **AC F02-5:** Diberikan admin idle 30 menit, ketika request berikutnya dilakukan, maka sesi admin tidak lagi berlaku. Peringatan UI muncul 2 menit sebelumnya; background polling tidak memperpanjang aktivitas.
- **AC F02-6:** Diberikan pengguna memilih keluar semua perangkat, ketika operasi berhasil, maka HTTP dan socket lama tidak dapat mengakses fitur terlindungi.

3.3 Iuran pendaftaran dan perpanjangan

F-03 | **P1** | **Cerita pengguna:** Sebagai alumni, saya ingin mengirim bukti iuran dan melihat statusnya agar aktivasi atau perpanjangan dapat diproses.

API menghitung nilai iuran dari pengaturan terversi dan menyimpan snapshot jumlah, jenis iuran, metode bayar dan periode. Nilai dari klien tidak dipercaya. Satu payment nonterminal untuk registration dan satu untuk renewal diperbolehkan per pengguna. Komponen biaya dikelola pengurus melalui web admin (settings.manage) dan dicatat terpisah: register alumni baru, pembuatan KTA, dan perpanjangan KTA per tahun. Nilai awal saat go-live adalah Rp50.000, Rp10.000 dan Rp10.000 per tahun; iuran registration terdiri atas register alumni baru ditambah pembuatan KTA, sedangkan renewal hanya perpanjangan (*disahkan v3.3*). Perubahan nominal hanya berlaku untuk payment baru. KTA digital adalah output R1.0; pengiriman kartu fisik bukan asumsi otomatis.

- **AC F03-1:** Diberikan anggota memenuhi syarat dan metode aktif, ketika instruksi pembayaran dibuat, maka nilai server dan tujuan bayar ditampilkan dengan payment_id yang tetap.
- **AC F03-2:** Diberikan pembayaran pending, ketika bukti baru diunggah, maka proof_version bertambah, bukti aktif diganti dan histori tercatat; tidak membuat pembayaran tambahan.
- **AC F03-3:** Diberikan iuran rejected, ketika pengguna memperbaiki bukti, maka payment yang sama kembali pending dengan versi baru dan alasan lama tetap pada histori.
- **AC F03-4:** Diberikan transaksi sudah paid/cancelled, ketika bukti hendak diganti, maka ditolak. Pengulangan request yang sama tidak menghasilkan biaya atau aktivasi ganda.
- **AC F03-5:** Diberikan harga pengaturan berubah setelah payment dibuat, ketika admin memutus payment tersebut, maka nilai snapshot tetap berlaku; perubahan harga hanya untuk transaksi baru.

3.4 Keputusan pembayaran pengurus

F-04 | **P1** | **Cerita pengguna:** Sebagai admin pembayaran, saya ingin memeriksa bukti dan mencatat keputusan agar anggota mendapat hasil yang jelas.

Admin melihat antrean berdasarkan waktu kirim bukti, jenis, dan usia. Keputusan mengunci payment dan memeriksa expected_version bukti. Paid berarti dana telah diverifikasi pengurus terhadap sumber pembayaran, bukan karena file bukti terlihat meyakinkan saja. Pengubahan paid ke rejected tidak tersedia; koreksi keuangan memerlukan catatan penyesuaian terpisah.

- **AC F04-1:** Diberikan pending dengan bukti valid, ketika disetujui, maka payment, payment_event, hak keanggotaan atau tiket, audit, dan outbox notifikasi disimpan dalam satu transaksi.
- **AC F04-2:** Diberikan penolakan, ketika alasan kosong atau hanya spasi dikirim, maka validasi gagal; alasan valid tersedia kepada pemilik pembayaran dan pengurus berizin.
- **AC F04-3:** Diberikan dua admin memutus payment yang sama, ketika permintaan bersamaan dijalankan, maka hanya satu keputusan berlaku; yang lain mendapat konflik beserta status terbaru.
- **AC F04-4:** Diberikan bukti telah diganti setelah admin membuka layar, ketika keputusan versi lama dikirim, maka ditolak sampai admin membaca versi baru.
- **AC F04-5:** Diberikan email/push sedang gagal, ketika keputusan disimpan, maka keputusan tetap committed, notifikasi in-app tersedia, dan worker mengulang pengiriman tanpa memperpanjang keanggotaan dua kali.

3.5 KTA digital dan cache offline

F-05 | **P1** | **Cerita pengguna:** Sebagai anggota aktif, saya ingin menampilkan KTA beserta QR dan masa berlaku, termasuk saat perangkat sementara tidak terhubung.

KTA mengikuti tampilan guidelines [R8] dan menampilkan foto jika tersedia, nama, angkatan, profesi, kode angkatan (misalnya KAPDH 25), kota domisili, nomor anggota, QR, masa berlaku, status (KTA Aktif atau KTA Tidak Aktif) dengan tombol Perpanjang, serta waktu sinkronisasi terakhir. Alamat yang tampil hanya kota, bukan alamat lengkap (*disahkan v3.3*). Kartu dibuat saat OTP pendaftaran terverifikasi dengan status Tidak Aktif dan menjadi Aktif setelah registration paid; kartu Tidak Aktif tidak dapat digunakan sebagai bukti keanggotaan. Format nomor anggota dan aturan perhitungannya ditetapkan di bawah (*disahkan v3.4*). Nomor urut N dibuat sekali, unik global, tidak didaur ulang, dan tidak diganti saat renewal maupun koreksi data. QR membawa token verifikasi bertanda tangan server, tanpa kontak atau secret. Kunci HMAC hanya di backend. Token memuat nomor atau identifier verifikasi, issuer, audience, issued_at, expires_at dan key_id. Umur token maksimal 7 hari, dibatasi expiry keanggotaan (*disahkan v3.2*); rotasi kunci menjaga token lama yang masih sah sampai batasnya tanpa memasukkan secret ke Flutter.

Format nomor anggota AA.SS.JK.N

Contoh: **12.01.01.7** berarti angkatan 12, tamat MTs dan Aliyah, laki-laki, nomor urut 7.

Segmen	Arti	Nilai
AA	Angkatan	2 digit, 01 sampai angkatan terbaru (30 pada 2026); bertambah satu setiap tahun
SS	Status pendidikan	01, 02 atau 03 sesuai tabel berikut
JK	Jenis kelamin	01 = laki-laki, 02 = perempuan
N	Nomor urut	Urut global dari server: 1, 2, 3 dan seterusnya, tanpa nol di depan dan tanpa batas jumlah digit

Kelas 1 sampai 3 adalah 1 sampai 3 MTs; kelas 4 sampai 6 adalah 1 sampai 3 Aliyah. Tamat MTs berarti masuk di MTs (kelas 1 sampai 3) dan keluar paling cepat di kelas 3. Tamat Aliyah berarti keluar di kelas 6 (3 Aliyah). Kelas keluar tidak boleh lebih rendah dari kelas masuk.

Kelas masuk	Kelas keluar	SS	Arti
1/2/3 MTs	3 Aliyah	01	Tamat MTs dan Aliyah
1/2/3 MTs	3 MTs	02	Tamat MTs
1/2/3 MTs	1/2 Aliyah	02	Tamat MTs
1/2/3 Aliyah	3 Aliyah	02	Tamat Aliyah
1/2 Aliyah	1/2 Aliyah	03	Tidak tamat
1/2 MTs	1/2 MTs	03	Tidak tamat

Tahun akademik. Tahun lulus = 1996 + angkatan; angkatan 1 lulus tahun 1997. Tahun keluar = tahun lulus - (6 - kelas keluar). Tahun masuk = tahun lulus - (6 - kelas masuk) - 1. Contoh guidelines: angkatan 30, masuk kelas 1, keluar kelas 6 menghasilkan tahun masuk 2020, tahun keluar 2026, tahun lulus 2026. Kode angkatan pada KTA ditulis "KAPDH" diikuti nomor angkatan (misalnya KAPDH 25), dan tahun lulus ditampilkan terpisah.

Proses penomoran. Server menghitung AA, SS dan JK dari data pendaftaran yang tersimpan dan mengambil N dari sequence saat OTP pendaftaran terverifikasi; klien tidak mengirim atau menentukan nomor. Gap N karena transaksi batal diterima. Setelah dibuat, angkatan, kelas, jenis kelamin dan nomor hanya dapat diubah admin dengan izin members.manage. Koreksi admin menghitung ulang prefix AA.SS.JK, mempertahankan N, mencatat

nomor lama dan baru pada audit, dan menerbitkan ulang token QR. Token QR terikat pada identifier internal anggota, bukan prefix, sehingga koreksi tidak membuat verifikasi salah sasaran.

- **AC F05-1:** Diberikan OTP pendaftaran terverifikasi, ketika akun diaktifkan, maka nomor anggota dialokasikan secara atomik satu kali dan KTA tampil berlabel Tidak Aktif beserta ajakan bayar; ketika registration paid, nomor yang sama dipakai kembali dan kartu menjadi Aktif dengan QR yang dapat diverifikasi online.
- **AC F05-2:** Diberikan kartu tersinkron <= 7 hari dan masa anggota belum habis, ketika perangkat offline, maka cache tampil dengan label Offline dan waktu sinkronisasi; ini bukan pembuktian status saat ini.
- **AC F05-3:** Diberikan cache lebih tua dari 7 hari, logout, perubahan akun, atau expiry sudah lewat, ketika kartu dibuka, maka tampilan aktif dihapus/dibatasi dan pengguna diminta sinkronisasi.
- **AC F05-4:** Diberikan anggota disuspend setelah sinkronisasi terakhir, ketika perangkat kembali online, maka cache tidak lagi tampil aktif. Verifikasi publik selalu memakai status server sehingga kartu offline tidak dapat digunakan untuk melewati suspend.
- **AC F05-5:** Diberikan renewal paid, ketika kartu diperbarui, maka nomor tetap dan expires_at mengikuti periode baru. Token QR lama tunduk expiry dan status terbaru di server.
- **AC F05-6:** Diberikan anggota dengan nomor 12.02.01.7, ketika admin mengoreksi kelas keluar menjadi kelas 6, maka nomor menjadi 12.01.01.7, N tetap 7, audit mencatat nomor lama dan baru, QR baru diterbitkan, dan tidak ada anggota lain yang dapat memakai N tersebut. Diberikan request yang mencoba mengirim nomor dari klien, maka nilai tersebut diabaikan atau ditolak.

3.6 Verifikasi KTA publik

F-06 | **P1** | **Cerita pengguna:** Sebagai pemeriksa KTA, saya ingin memindai QR agar dapat mengetahui apakah keanggotaan berlaku.

Situs /kta/{nomor} menyediakan shell pemeriksa dan mengirim token QR ke API. Nomor saja tidak memberi akses profil. Verifikasi memeriksa signature, issuer/audience, expiry token, keterikatan pada nomor, serta status terkini. Respons publik hanya status, masa berlaku, waktu pemeriksaan dan identitas minimum yang disahkan D3; tidak ada email, telepon, NIK, alamat, bukti bayar atau alasan suspend.

Usulan: token diletakkan pada fragmen URL (misalnya `/kta/{nomor}#t=<token>`) agar tidak terkirim ke server web, tidak tercatat di access log proxy, dan tidak bocor melalui header Referer. Shell membaca fragmen lalu mengirim token ke API verifikasi.

- **AC F06-1:** Diberikan token valid dan anggota aktif, ketika dipindai, maka respons Aktif beserta checked_at muncul; expiring tetap Aktif dengan tanggal habis.
- **AC F06-2:** Diberikan anggota yang belum membayar iuran pendaftaran, expired, suspended/disabled, atau nomor tidak ada termasuk setelah penghapusan akun, ketika dipindai, maka masing-masing tampil Kedaluwarsa, Tidak aktif, atau Tidak ditemukan tanpa membocorkan alasan privat.
- **AC F06-3:** Diberikan token diubah atau kedaluwarsa, ketika verifikasi dilakukan, maka tidak ada status Aktif; UI menampilkan QR tidak valid atau perlu diperbarui.
- **AC F06-4:** Diberikan API tidak terjangkau, ketika scan dilakukan, maka tampil Tidak dapat memverifikasi dan retry; tidak mengubah keadaan jaringan menjadi Tidak ditemukan.

3.7 Periode keanggotaan

F-07 | **P1** | **Cerita pengguna:** Sebagai anggota, saya ingin mengetahui tanggal habis dan memperpanjang tanpa kehilangan sisa masa aktif.

Registration aktif mulai approved_at dan berlaku 12 bulan kalender. Renewal menambah 12 bulan dari max(expires_at lama, approved_at). Tanggal transfer yang dilaporkan pengguna tidak menjadi sumber aktivasi karena belum diverifikasi. Expiring berlaku saat sisa masa aktif <= 30 hari dan > 0. Tidak ada masa tenggang akses setelah habis (*disahkan v3.2*).

- **AC F07-1:** Diberikan anggota belum expired, ketika renewal paid, maka masa baru dimulai dari expires_at lama; sisa masa aktif tidak hilang.
- **AC F07-2:** Diberikan anggota telah expired, ketika renewal paid, maka masa baru dihitung dari approved_at dan akses aktif kembali bila tidak suspended.
- **AC F07-3:** Diberikan batas waktu terlewati sementara worker terlambat, ketika API diakses, maka status tetap dihitung benar dari timestamp; hak tidak bergantung pada jadwal worker.
- **AC F07-4:** Diberikan anggota suspended, ketika pembayaran lama akhirnya disetujui, maka periode boleh diperbarui sesuai kebijakan, tetapi effective_status tetap suspended.
- **AC F07-5:** Diberikan reminder 30 hari sebelum habis, ketika job diulang, maka satu notifikasi per periode dibuat. Jendela renewal dibuka mulai 30 hari sebelum habis dan tetap terbuka setelah expired (*disahkan v3.2*).

3.8 Beranda, berita dan halaman informasi

F-08 | **P1** | **Cerita pengguna:** Sebagai anggota, saya ingin menemukan informasi resmi dan kegiatan mendatang pada beranda.

Beranda berisi banner aktif, kegiatan mendatang, feed berita published, dan akses cepat KTA/notifikasi. Berita memiliki draft, published dan archived; penerbitan terjadwal menggunakan published_at. Halaman tentang, privasi, ketentuan dan bantuan dapat dibaca sebelum aktivasi. Cover dan rich text disanitasi; tautan luar diberi indikasi yang jelas.

- **AC F08-1:** Diberikan draft, konten berjadwal masa depan dan archived, ketika feed anggota dipanggil, maka hanya published yang sudah waktunya tampil.
- **AC F08-2:** Diberikan banner di luar jendela tanggalnya, ketika beranda dibuka, maka banner tidak tampil dan target yang sudah tidak tersedia ditangani dengan pesan yang jelas.
- **AC F08-3:** Diberikan pengguna menekan like berulang atau request diulang, ketika server memproses, maka maksimal satu like per user/post dan penghitung tetap konsisten.
- **AC F08-4:** Diberikan jaringan putus atau feed kosong, ketika beranda dibuka, maka tampil retry atau keadaan kosong yang membantu; cache lama diberi waktu pembaruan.

3.9 Event, pemesanan dan check-in

F-09 | **P2** | **Cerita pengguna:** Sebagai anggota aktif, saya ingin mendaftar ke kegiatan, menerima tiket dan check-in tanpa perebutan kuota yang tidak jelas.

Event memiliki tanggal mulai/selesai, zona waktu, lokasi, jendela pendaftaran, harga, kuota, dan aturan pembatalan. Satu anggota hanya dapat memiliki satu tiket aktif per event, dan tiket tersebut berlaku untuk dirinya sendiri (1 orang); tidak ada pemesanan untuk rombongan atau tamu (*disahkan v3.2*). Setiap tiket paid memiliki satu QR unik dan dicatat check-in satu kali.

Reservasi tanpa bukti berlaku 24 jam atau sampai registration_closes_at, mana yang lebih dahulu. Bukti yang dikirim tepat waktu memindahkan tiket ke awaiting_review dan menahan kursi sampai keputusan. Antrean yang lewat 2 hari kerja dieskalasi, bukan dibatalkan otomatis, karena dana mungkin sudah ditransfer. Jendela check-in dibuka 2 jam sebelum acara dimulai sampai acara selesai, kecuali event menetapkan jendela lain (*disahkan v3.5*).

Pembatalan dan refund (D6, *disahkan v3.5*). Refund pada R1.0 diproses manual oleh bendahara dan dicatat sebagai payment_adjustment.

Situasi	Aturan
Event dibatalkan pengurus	Refund penuh kepada seluruh peserta berbayar
Peserta membatalkan sendiri	Diperbolehkan sampai H-3 dengan refund penuh; setelah itu tanpa refund
Pemroses dan tenggat	Bendahara, paling lambat 7 hari kerja sejak pembatalan
Cara refund	Transfer manual; rekening tujuan diminta saat proses refund saja dan dihapus setelah selesai sesuai D2
Keanggotaan habis sebelum event	Tiket tetap berlaku
Anggota disuspend	Tiket tidak berlaku; refund diputuskan pengurus per kasus
Akun dihapus	Tiket hangus; sebelum konfirmasi penghapusan, pengguna diberi tahu untuk mengajukan refund lebih dahulu
Event gratis	Tidak ada refund; pembatalan melepas kursi

- **AC F09-1:** Diberikan kuota tersisa q, ketika request paralel dari anggota berbeda berebut kursi, maka jumlah held dan paid tidak melebihi seats_total; transaksi yang gagal tidak meninggalkan hold.
- **AC F09-2:** Diberikan reservasi tanpa bukti lewat batas, ketika expiry job atau request berikutnya berjalan, maka tiket expired dan kursi dilepas tepat sekali; bukti baru sesudah batas ditolak.
- **AC F09-3:** Diberikan event gratis, ketika pendaftaran valid dibuat, maka tiket langsung paid dengan total 0 tanpa payment palsu dan QR tiket diterbitkan.
- **AC F09-4:** Diberikan bukti tiket ditolak, ketika keputusan committed, maka payment rejected, tiket cancelled dan hold dilepas. Pendaftaran ulang membuat tiket/payment baru; bukti tidak menghidupkan tiket yang dibatalkan.
- **AC F09-5:** Diberikan tiket paid dalam jendela check-in, ketika dipindai admin events.checkin, maka checked_in_at dan aktor disimpan atomik. Scan kedua menampilkan Sudah check-in tanpa menambah hitungan.
- **AC F09-6:** Diberikan QR event lain, pending, expired, cancelled, atau di luar jendela, ketika dipindai, maka check-in ditolak dengan alasan yang dapat ditindaklanjuti.
- **AC F09-7:** Diberikan event cancelled, ketika status berubah, maka QR seluruh tiket tidak berlaku, notifikasi peserta dijadwalkan, dan refund manual mengikuti register; event/transaksi historis tidak dihapus.

3.10 Direktori dan profil anggota

F-10 | **P2** | **Cerita pengguna:** Sebagai anggota aktif, saya ingin menemukan alumni berdasarkan identitas komunitas, profesi atau keahlian dengan menghormati privasi mereka.

Direktori hanya menampilkan anggota verified/expiring yang tidak suspended dan mengizinkan penampilan profil. Pencarian mencakup nama, angkatan, kelas dan kota; filter profesi serta keahlian memakai master terkontrol. Paging default 30, maksimum usulan 100. Kontak dan tautan sosial default tersembunyi sampai pemilik mengaktifkan flag. Mematikan visibilitas tidak menghalangi pengurus berizin mengakses data untuk tujuan administratif yang tercatat.

- **AC F10-1:** Diberikan anggota aktif berizin, ketika direktori dicari/filter, maka hasil dan total mengikuti filter serta status terkini tanpa duplikasi paging.

- **AC F10-2:** Diberikan show_phone=false, ketika API profil maupun pencarian dipanggil, maka nilai telepon tidak ikut payload; masking bukan sekadar penyembunyian di UI.
- **AC F10-3:** Diberikan pengguna unverified/expired/suspended atau publik, ketika endpoint direktori dipanggil langsung, maka ditolak.
- **AC F10-4:** Diberikan master dinonaktifkan, ketika profil yang sudah memakainya dibaca, maka label historis tetap dapat ditampilkan, tetapi pemilihan baru tidak tersedia.
- **AC F10-5:** Diberikan profil milik orang lain, ketika pengguna mencoba mengubahnya dengan mengganti ID, maka ditolak dan tidak ada field yang berubah.

3.11 Chat langsung dan grup

F-11 | **P2** | **Cerita pengguna:** Sebagai anggota aktif, saya ingin berkomunikasi dengan alumni melalui pesan langsung atau grup, dengan status kirim yang dapat dipercaya.

Chat mendukung teks, gambar, reply, reaksi, status terkirim/terbaca, unread, typing, presence, mute dan keluar grup. Server membatasi room membership pada setiap read, send, upload dan subscribe. Pesan memiliki client_message_id unik per pengirim agar retry tidak menduplikasi. Riwayat memakai keyset (created_at, id). Batas teks 4.000 karakter dan anggota grup 100 (*disahkan v3.2*).

- **AC F11-1:** Diberikan pasangan aktif tanpa blokir, ketika direct chat dibuat bersamaan dari dua perangkat, maka hanya satu room dengan direct_key kanonik dibuat.
- **AC F11-2:** Diberikan pesan valid, ketika dikirim, maka server acknowledge sesudah commit; pengulangan client_message_id mengembalikan pesan yang sama.
- **AC F11-3:** Diberikan koneksi terputus sesudah commit, ketika reconnect, maka klien menyinkron pesan setelah cursor terakhir dan tidak kehilangan pesan yang tidak sempat menerima event.
- **AC F11-4:** Diberikan pengguna bukan anggota room atau sudah keluar, ketika history/file/subscribe diminta, maka ditolak; UUID room bukan izin akses.
- **AC F11-5:** Diberikan admin grup terakhir hendak keluar, ketika ada anggota lain, maka pemindahan peran admin wajib untuk keluar biasa. Penghapusan akun memakai aturan pengalihan sistem agar tidak terhambat.
- **AC F11-6:** Diberikan anggota menjadi expired/suspended saat socket tersambung, ketika mengirim atau bergabung room, maka server menolak dan mencabut subscription yang tidak lagi berizin.

Presence dan typing bersifat sementara dengan TTL, bukan bukti bahwa pesan dibaca. Pemutakhiran last_read tidak boleh mundur akibat paket terlambat. Grup baru menerima anggota melalui undangan yang harus diterima calon anggota; pengguna tidak dipaksa masuk. Default R1.0: hanya admin grup yang dapat mengundang, dan anggota baru hanya melihat pesan sejak bergabung (*default v3.5, dapat diubah melalui change request*).

3.12 Blokir, pelaporan dan moderasi

F-12 | **P2** | **Cerita pengguna:** Sebagai anggota, saya ingin menghentikan pesan langsung dan melaporkan penyalahgunaan; sebagai moderator, saya ingin menilai bukti tanpa mengakses chat lain secara bebas.

Blokir berlaku dua arah untuk pengiriman direct dan undangan grup dari pasangan tersebut. Histori pesan lama tetap tersedia kepada pemilik room. Pada grup yang sama, blokir tidak membatalkan aturan room atau menghapus pesan milik orang lain; UI menyediakan mute dan laporan. Laporan menyimpan bukti relevan yang diminimalkan, agar moderasi tidak kehilangan konteks ketika pesan dihapus. Akses bukti dibatasi dan diaudit.

- **AC F12-1:** Diberikan blokir aktif dari salah satu pihak, ketika direct send dilakukan dari pihak mana pun, maka server menolak walaupun socket/room sudah ada.

- **AC F12-2:** Diberikan laporan pengguna/pesan yang dapat diakses pelapor, ketika dikirim, maka laporan terdaftar, dapat dipantau pelapor, dan tidak dibuka kepada pihak terlapor.
- **AC F12-3:** Diberikan moderator dengan izin, ketika dismiss/warn/suspend/unsuspend dijalankan, maka alasan, aktor, waktu dan bukti keputusan dicatat. Warn tidak mengubah tanggal keanggotaan.
- **AC F12-4:** Diberikan suspend, ketika committed, maka sesi umum serta akses komunitas dicabut, direktori menyembunyikan profil, dan verifikasi KTA menjadi Tidak aktif.
- **AC F12-5:** Diberikan unsuspend, ketika committed, maka status dihitung ulang dari expires_at; anggota yang masa aktifnya habis menjadi expired, bukan otomatis verified.

Moderasi hanya dilakukan melalui web admin oleh pengurus dengan izin moderation; aplikasi Flutter tidak memiliki menu atau login pengurus (*disahkan v3.2*). Target penanganan laporan: risiko ancaman/keselamatan dalam 24 jam, laporan lain 2 hari kerja (*disahkan v3.2*). Kontak dukungan, ketentuan komunitas, filter dasar konten berbahaya dan mekanisme banding wajib tersedia sebelum chat dibuka. Bukti laporan mengikuti kebijakan D2. Pedoman moderasi mengikuti kewajiban UGC toko aplikasi [R6].

3.13 Notifikasi dan preferensi

F-13 | **P1** | **Cerita pengguna:** Sebagai pengguna, saya ingin memperoleh hasil penting serta memilih kategori push yang saya terima.

Kotak masuk in-app merupakan riwayat resmi. Push FCM untuk Android dan APNs melalui FCM untuk iOS, serta email transaksional, dikirim worker dari outbox. Kategori meliputi pembayaran, masa KTA, event, berita dan chat. OTP, keamanan akun, serta konfirmasi penghapusan tidak diperlakukan sebagai promosi. Preferensi push tidak menghilangkan riwayat keputusan in-app.

- **AC F13-1:** Diberikan keputusan pembayaran, ketika committed, maka satu notification_id tercipta dan email/push dijadwalkan sesuai kategori serta preferensi; retry tidak menduplikasi inbox.
- **AC F13-2:** Diberikan pengguna menolak izin push OS atau mematikan kategori, ketika peristiwa terjadi, maka aplikasi tetap berfungsi dan inbox tetap dapat dibuka.
- **AC F13-3:** Diberikan deep link, ketika notifikasi diketuk setelah logout atau perubahan hak, maka autentikasi/otorisasi diperiksa sebelum membuka objek.
- **AC F13-4:** Diberikan token FCM UNREGISTERED, ketika pengiriman gagal, maka token dinonaktifkan; gangguan sementara 429/5xx menggunakan retry/backoff dan tidak langsung menonaktifkan token [R5].
- **AC F13-5:** Diberikan pengguna keluar atau berganti akun, ketika perangkat diperbarui, maka token perangkat tidak lagi menerima notifikasi akun sebelumnya.
- **AC F13-6:** Diberikan event H-3/H-1 atau pengingat expiry, ketika job berjalan berulang, maka kunci event/pengguna/periode mencegah pengiriman ganda dan jadwal usang dibatalkan saat event berubah.

Payload layar kunci default tidak memuat isi chat, bukti bayar atau data kontak. Status provider Accepted berarti diterima provider, bukan jaminan telah dibaca perangkat. Kegagalan kanal ditampilkan ke pengurus untuk retry yang terkendali. Skema deep link (rute dan parameter per kategori) didefinisikan dalam kontrak API bersama payload notifikasi.

3.14 Penghapusan akun

F-14 | **P1** | **Cerita pengguna:** Sebagai pengguna, saya ingin menghapus akun beserta data terkait dan mengetahui data terbatas yang perlu tetap disimpan.

Alur tersedia di pengaturan Flutter serta /delete-account yang dapat dipakai tanpa memasang aplikasi. Halaman web benar-benar menerima permintaan dengan autentikasi/challenge, bukan hanya menjelaskan agar pengguna

menghubungi pengurus. Reautentikasi maksimal berumur 10 menit dan konfirmasi eksplisit diperlukan. Akun suspended mendapat challenge deletion-only tanpa akses komunitas. Ketentuan in-app dan web mengikuti [R1] serta [R2].

- **AC F14-1:** Diberikan identitas telah diverifikasi, ketika konfirmasi dilakukan, maka satu deletion job dibuat, akun menjadi deletion_pending, sesi/socket dicabut, dan nomor permintaan tampil.
- **AC F14-2:** Diberikan worker gagal di salah satu langkah, ketika retry dijalankan, maka steps_done dilanjutkan tanpa menghapus data pengguna lain atau menghitung ulang transaksi.
- **AC F14-3:** Diberikan deletion selesai, ketika data diperiksa, maka kredensial, profil, kontak, token perangkat, avatar, unggahan pribadi, dan konten chat yang dibuat pengguna dihapus atau menjadi placeholder tanpa isi; account linkage dan snapshot keuangan dibersihkan.
- **AC F14-4:** Diberikan payment/ticket historis, ketika dianonimkan, maka jumlah, tanggal, status dan referensi transaksi minimum tetap ada tanpa nama/email/telepon/foto atau snapshot identitas; file bukti asli dihapus.
- **AC F14-5:** Diberikan pengguna admin grup terakhir, ketika akun dihapus, maka sistem mengalihkan ke anggota aktif yang memenuhi kebijakan atau menutup grup; penghapusan akun tidak bergantung pada respons anggota lain.
- **AC F14-6:** Diberikan restore backup yang dibuat sebelum penghapusan, ketika layanan dipulihkan, maka deletion ledger diterapkan ulang sebelum layanan dibuka sehingga data yang sudah dihapus tidak muncul kembali.

Usulan penyelesaian otomatis <= 7 hari kalender dan pemberitahuan setelah selesai. Kebijakan D2 (*disahkan v3.2*): tidak ada periode retensi data pribadi setelah akun dihapus. Data pribadi, kontak, unggahan, dan file bukti transfer dihapus oleh deletion job. Catatan keuangan, tiket, laporan moderasi dan audit hanya dipertahankan dalam bentuk anonim tanpa nama, email, telepon, foto, atau snapshot identitas. Backup harian tetap berotasi 30 hari untuk pemulihan bencana; deletion ledger memastikan data yang sudah dihapus tidak aktif kembali setelah restore. Ketentuan ini dijelaskan kepada pengguna sebelum konfirmasi penghapusan. Akun pengurus terakhir memerlukan pengalihan kewenangan terlebih dahulu; akun alumni pribadinya tetap dapat dihapus terpisah.

3.15 Portal pengurus dan pengelolaan data

F-15 | **P1** | **Cerita pengguna:** Sebagai pengurus, saya ingin melihat pekerjaan yang perlu tindakan dan mengelola modul sesuai tanggung jawab saya.

Dasbor menampilkan pembayaran menunggu, reservasi/antrean terlambat, laporan terbuka, event mendatang, serta job gagal sesuai izin. Menu mencakup anggota, iuran, konten, banner, halaman, event/tiket, master profesi/keahlian, metode bayar, pengaturan, admin dan audit. Tabel menggunakan pencarian/filter/paging server; aksi massal dibatasi pada tindakan yang aman dan dapat diaudit.

- **AC F15-1:** Diberikan admin pembayaran tanpa izin konten, ketika dashboard/menu/API diakses, maka hanya data pembayaran tersedia dan endpoint konten menolak perubahan.
- **AC F15-2:** Diberikan event sudah memiliki tiket, ketika admin mencoba menghapus atau menurunkan kuota di bawah held+paid, maka ditolak; event dapat dibatalkan dengan alur notifikasi/refund.
- **AC F15-3:** Diberikan perubahan biaya/metode bayar/versi aplikasi minimum, ketika disimpan, maka reautentikasi sesuai sensitivitas, snapshot versi konfigurasi dan audit tercatat; transaksi lama tidak berubah.
- **AC F15-4:** Diberikan versi objek telah berubah, ketika admin menyimpan formulir lama, maka API memberi konflik versi dan UI menawarkan muat ulang, bukan menimpa diam-diam.
- **AC F15-5:** Diberikan penerbitan konten terjadwal, ketika waktunya tiba, maka worker menerbitkan sekali; konten yang telah diarsipkan tidak hidup kembali oleh job lama.

3.16 Administrasi akun dan izin

F-16 | **P1** | **Cerita pengguna:** Sebagai Super Admin, saya ingin menugaskan pengurus dan membantu pemulihan akun dengan kontrol yang dapat ditelusuri.

Akun admin tetap terpisah dari akun alumni (*disahkan v3.3*). Menu "Delegasi User Jadi Admin" pada guidelines [R8] diwujudkan sebagai undangan admin: Super Admin memilih alumni, sistem membuat identitas admin baru yang ditautkan ke akun alumni tersebut untuk pemeriksaan konflik kepentingan, tanpa memberi hak admin pada sesi aplikasi alumni. Provisioning admin bersifat undangan tertutup. Admin harus mengganti sandi awal melalui token sekali pakai dan mendaftarkan TOTP sebelum aktivasi. Super Admin pertama dibuat melalui prosedur bootstrap pada bagian 8.2, bukan melalui endpoint publik. Reset sandi alumni berarti mengirim challenge pemulihan berumur pendek dan mencabut sesi, bukan menampilkan atau menentukan sandi pengguna kepada pengurus.

- **AC F16-1:** Diberikan Super Admin dengan MFA serta reautentikasi, ketika admin/izin dibuat atau diubah, maka perubahan valid tersimpan dan tercatat pada audit.
- **AC F16-2:** Diberikan hanya satu Super Admin aktif, ketika dua request bersamaan mencoba menonaktifkan/menurunkannya, maka constraint transaksi tetap menjaga minimal satu; pemeriksaan jumlah biasa tanpa locking tidak cukup.
- **AC F16-3:** Diberikan izin admin dicabut, ketika API/socket dipakai lagi, maka hak yang dicabut tidak berlaku meskipun token belum expired.
- **AC F16-4:** Diberikan reset alumni, ketika diproses, maka seluruh sesi target dicabut, target diberi notifikasi keamanan, dan challenge baru diserahkan hanya melalui kanal terverifikasi.

3.17 Audit dan ekspor

F-17 | **P1** | **Cerita pengguna:** Sebagai pengurus berizin, saya ingin menelusuri perubahan penting agar dapat memeriksa akuntabilitas dan menangani sengketa.

Audit memuat aktor, effective role, tindakan, entitas, waktu UTC, request_id, alasan, serta before/after yang telah disaring. Cakupan wajib: keputusan dan koreksi pembayaran, keanggotaan, kuota/event/tiket/check-in, admin/izin, moderasi, metode bayar, konfigurasi, ekspor, penghapusan akun, serta bootstrap dan seed produksi. Application role tidak boleh mengubah/menghapus audit.

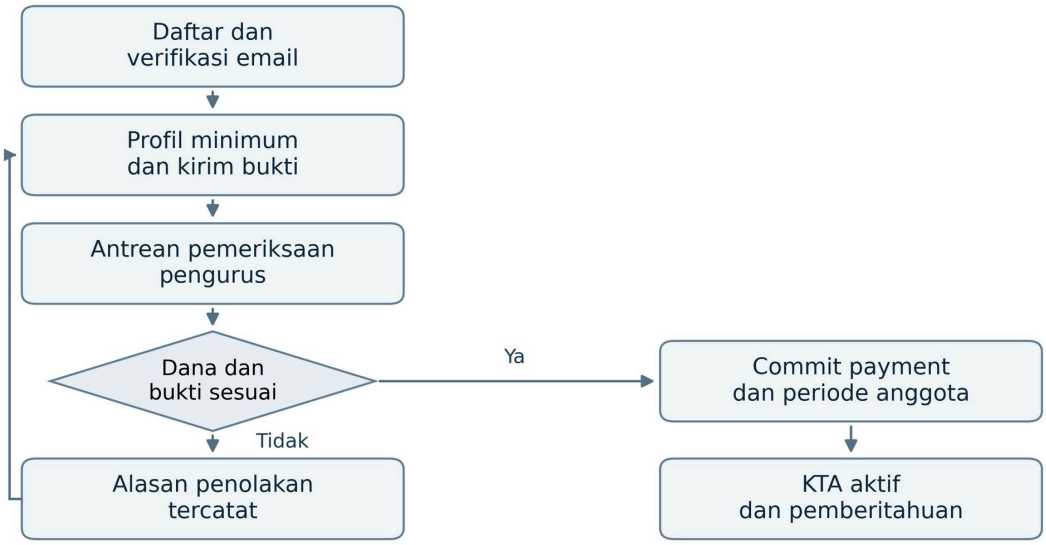
- **AC F17-1:** Diberikan perubahan kritis, ketika transaksi committed, maka satu audit berkorelasi tersedia; kegagalan mencatat audit membatalkan perubahan kritis.
- **AC F17-2:** Diberikan pengguna tanpa audit.read/export, ketika daftar atau CSV diminta, maka ditolak walaupun URL file diketahui.
- **AC F17-3:** Diberikan ekspor, ketika nilai dimulai dengan =, +, -, atau @, maka formula CSV dinetralkan; kolom privat dan secret tidak ikut ekspor.
- **AC F17-4:** Diberikan pencarian audit, ketika aktor/entitas/waktu difilter, maka hasil dan ekspor memakai filter yang sama. Ekspor besar dijalankan worker dan file privatnya otomatis kedaluwarsa.

Audit bukan salinan seluruh payload. Password hash, OTP, refresh token, secret TOTP, isi chat, bukti bayar dan NIK tidak pernah dicatat. Saat akun dihapus, identitas aktor pada audit dianonimkan sesuai D2. Audit bersifat append-only bagi application role; pembersihan resmi hanya dijalankan role terpisah dengan catatan kebijakan.

4 Alur pengguna dan siklus status

4.1 Aktivasi anggota

Alumni mengisi data diri, membuktikan email melalui OTP, lalu menerima nomor anggota dengan KTA berstatus Tidak Aktif. Alumni membaca nominal dan tujuan bayar, lalu mengirim bukti. Flutter menampilkan status menunggu dan histori. Pengurus membuka bukti versi terbaru serta mencocokkan dana, kemudian menyetujui atau menolak dengan alasan. Persetujuan secara atomik mengaktifkan KTA dengan periode, audit dan outbox. Worker mengirim hasil dan kartu menjadi Aktif. Penolakan iuran kembali ke perbaikan bukti pada payment yang sama.



Gambar 1 Alur aktivasi keanggotaan

4.2 Identitas keanggotaan dan moderasi

Keadaan awal	Pemicu	Hasil dan penjagaan
pending_otp	OTP signup benar	users.active; keanggotaan unverified; nomor anggota dialokasikan sekali, KTA Tidak Aktif
unverified	registration paid	KTA Aktif dengan nomor yang sama, starts_at=approved_at, expires_at=+12 bulan
verified	Sisa waktu <= 30 hari dan > 0	expiring; tetap mendapat akses aktif
verified atau expiring	now >= expires_at	expired; tidak menunggu worker
expiring atau expired	renewal paid	Periode baru dari max(expiry lama, approved_at)
Keanggotaan apa pun	suspend	effective_status suspended; tanggal periode tidak dibuang
suspended	unsuspend	Hitung ulang berdasarkan verifikasi dan waktu, bukan selalu verified
Akun yang dapat dihapus	Konfirmasi deletion	deletion_pending; sesi dicabut, lalu data dihapus/anonim

Riwayat periode dan moderasi dipisahkan agar tanggal habis tidak hilang ketika suspend. effective_status dihitung dari data canonical (verifikasi, periode, dan moderasi), bukan dari kolom status yang dapat diubah langsung. Jika kolom status turunan dipakai untuk kebutuhan performa, nilainya hanya projection yang dihitung API dan diuji tidak dapat membuka akses yang seharusnya ditolak.

4.3 Pembayaran dan versi bukti

Payment pending dapat memiliki proof_file_id kosong saat instruksi dibuat, tetapi tidak dapat disetujui sebelum bukti lengkap. proof_version bertambah setiap unggah/ganti bukti. rejected untuk iuran dapat kembali pending; rejected untuk tiket bersifat final terhadap order tersebut.

Transisi	Pelaku dan kondisi	Efek
Baru ke pending	Pengguna memenuhi syarat, nilai server	Snapshot iuran/metode/tujuan; belum ada hak aktif
pending ke pending	Pemilik mengganti bukti sebelum keputusan	Versi bertambah, histori bukti lama tidak menjadi bukti aktif
pending ke paid	Admin berizin, dana terverifikasi, versi cocok	Periode/tiket, audit dan outbox atomik
pending ke rejected	Admin berizin, alasan wajib	Iuran boleh diperbaiki; tiket dibatalkan dan hold dilepas
rejected ke pending	Hanya registration/renewal, pemilik kirim ulang	Payment sama, versi baru dan alasan lama tetap tersimpan
pending ke cancelled	Pemilik membatalkan sebelum bukti atau kebijakan admin	Tidak membuka akses; alasan dan aktor tersimpan
paid ke penyesuaian	Pengurus berwenang melalui catatan terpisah	Rekam koreksi/refund tanpa menimpa transaksi asal

Request dengan Idempotency-Key yang sama dan payload sama mengembalikan hasil operasi sebelumnya. Key sama dengan payload berbeda menghasilkan konflik. Usulan masa simpan key 24 jam; kunci domain seperti keputusan payment dan client_message_id tetap memastikan deduplikasi setelah masa itu. Klien menyimpan key secara lokal sampai hasil operasi diketahui, sehingga pengulangan setelah jaringan putus memakai key yang sama.

4.4 Event dan inventori kursi

Status event: draft, open, closed, done, cancelled. Event open menerima reservasi hanya dalam jendela tanggal, kuota cukup, dan akun memenuhi syarat. closed menutup pemesanan baru; paid masih berlaku untuk check-in. cancelled menutup pemesanan serta check-in. Selesai/done diset sesudah kegiatan berakhir. Event yang sudah memiliki riwayat tiket tidak dihapus.

Status tiket: awaiting_payment, awaiting_review, paid, expired, cancelled. awaiting_payment/awaiting_review menahan kursi. paid mengonsumsi kursi. expired/cancelled tidak mengonsumsi kursi. Formula: seats_available = seats_total - held_quantity - paid_quantity. Satu tiket selalu bernilai satu kursi. checked_in adalah atribut tiket, bukan pengurangan inventori kedua kali.

Keadaan	Pemicu	Hasil
Kuota tersedia	Anggota mendaftar (1 kursi), belum punya tiket aktif di event ini	awaiting_payment dan hold atomik

Keadaan	Pemicu	Hasil
awaiting_payment	Bukti valid sebelum hold_expires_at	awaiting_review; kursi tetap held
awaiting_payment	Waktu habis tanpa bukti	expired; hold dilepas sekali
awaiting_review	Admin approve	paid, held berubah menjadi paid, QR tiket diterbitkan
awaiting_review	Admin reject	cancelled, payment rejected, kursi dilepas
Event gratis	Reserve valid	Langsung paid, total nol, QR tiket diterbitkan
Tiket paid belum hadir	Scan berizin dalam jendela	checked_in_at tercatat satu kali
Event cancelled	Keputusan pengurus	Seluruh QR tidak berlaku dan proses refund/notifikasi dicatat

Pembayaran yang belum diputus sesudah pendaftaran ditutup tetap berada dalam antrean; admin harus menyelesaikan sebelum check-in. D5 menentukan batas operasional review untuk event dekat hari H. Harga event tidak boleh diubah untuk tiket yang sudah dibuat. Pembatalan paid, suspend pemegang tiket, atau penghapusan akun tidak otomatis menganggap dana sudah dikembalikan; catatan penyelesaian keuangan tersendiri diperlukan.

4.5 Alur pengecualian dan keadaan layar

Pemicu	Perilaku pengguna	Perilaku sistem
Jaringan putus saat bayar/reserve	Tampil Memeriksa status; pengguna tidak diminta mengulang transfer	Query hasil via key/payment/tiket sebelum retry mutasi
Email atau push gagal	Status resmi tetap terlihat di inbox/riwayat	Retry worker; pengurus melihat kegagalan kanal
Bukti tidak valid	Tampilkan tipe/ukuran yang diterima dan kesempatan koreksi	Tidak mengubah payment menjadi paid atau memakai kuota unggah sukses
Objek telah diubah admin lain	Tampil status terbaru dan tombol muat ulang	HTTP 409 dengan kode konflik versi
Keanggotaan berakhir saat chat	Tampilkan ajakan perpanjang dan tahan pengiriman	Server menolak pesan baru dan menutup subscription terlindungi
QR telah digunakan	Tampilkan waktu dan petugas check-in sebelumnya	Tidak membuat check-in kedua
Maintenance terjadwal	Jelaskan rentang estimasi, retry dan kanal dukungan	Kode MAINTENANCE; menolak mutasi, read-only terkontrol
Versi aplikasi di bawah minimum	Layar wajib update dengan tautan toko aplikasi	Konfigurasi versi minimum dari API publik; tidak memproses mutasi dari versi yang tidak didukung
API verifikasi KTA down	Tampil Tidak dapat memverifikasi	Tidak memberi hasil aktif dari cache publik

Semua form penting menyimpan input nonrahasia ketika kegagalan jaringan terjadi. Loading, kosong, error, success dan izin ditolak memiliki pesan serta tindakan yang spesifik. Status tidak dibedakan dengan warna saja.

Konfirmasi diperlukan untuk reject, suspend, pembatalan event, penghapusan dan perubahan izin.

4.6 Peta layar

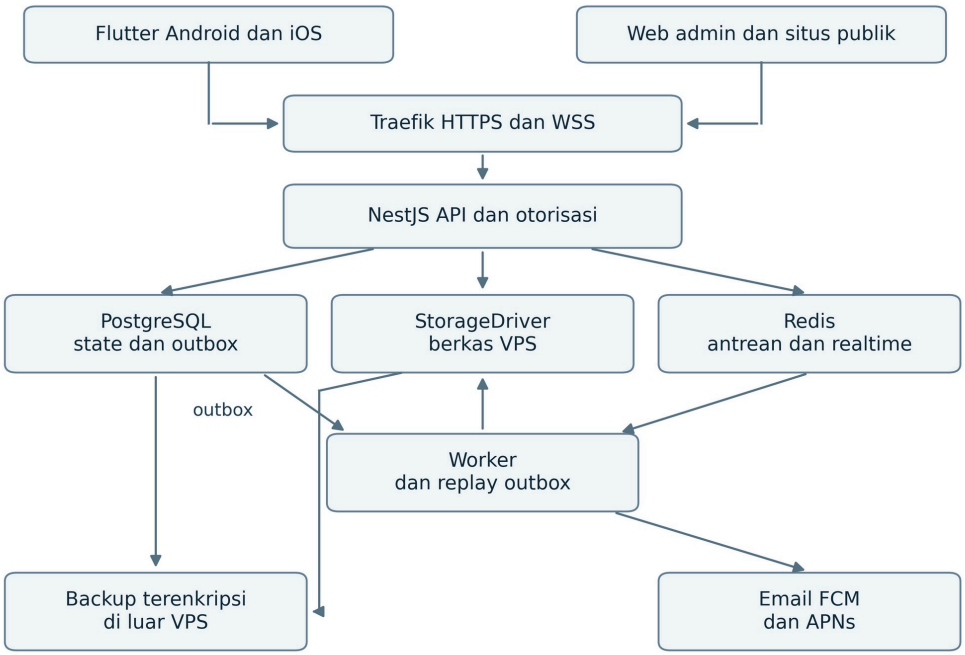
Kanal	Layar wajib	Fokus informasi
Flutter sistem	Splash, wajib update, maintenance, tanpa koneksi	Kesiapan aplikasi dan versi yang didukung
Flutter auth	Login, daftar, OTP, lupa/ganti sandi	Challenge, cooldown dan pemulihan
Flutter onboarding	Profil minimum, bayar iuran, menunggu/ditolak	Nominal, tujuan, bukti dan alasan
Flutter utama	Beranda, berita, event/detail, tiket QR	Informasi resmi dan kegiatan
Flutter anggota	KTA, direktori/profil, perpanjangan	Masa aktif, privasi dan kontak terizin
Flutter komunikasi	Daftar chat, direct/grup, info grup, blokir/laporan	Riwayat, status kirim dan kontrol
Flutter akun	Inbox, preferensi, profil, sesi, legal, hapus akun	Kendali identitas dan data
Web admin	Login/TOTP, dashboard, seluruh menu berizin termasuk moderasi	Antrean tindakan, filter, versi, audit
Situs publik	Beranda, unduh aplikasi, legal, kontak, KTA verify, delete-account	Identitas minimum dan penghapusan mandiri

Seluruh layar Flutter dan web admin dibangun baru mengikuti Guidelines KAPDH v1.0 [R8]. Layar yang sudah ada di guidelines (login, daftar, KTA, jejaring, event dan tiket, serta menu web admin) menjadi acuan; layar yang belum ada (OTP, menunggu dan ditolak, inbox, sesi, hapus akun, wajib update, maintenance, chat, review pembayaran rinci) diprototipekan dengan gaya yang sama.

5 Arsitektur dan operasi

5.1 Batas sistem

Flutter, web admin dan situs publik hanya memakai API melalui Traefik dengan HTTPS/WSS. API NestJS mengatur auth, membership, payments, content, events, network, chat, notifications, admin, files dan account. PostgreSQL menyimpan state durable; Redis menyimpan antrean BullMQ, rate limit dan adapter realtime. Worker memproses email/push, pengingat, expiry, ekspor, cleanup dan penghapusan akun.



Gambar 2 Arsitektur layanan

Outbox disimpan bersama perubahan bisnis di PostgreSQL. Dispatcher meneruskan ke BullMQ dengan dedup key. Jika Redis/job hilang atau dispatcher mati setelah commit, outbox tetap dapat diproses ulang. Redis bukan satu-satunya catatan keputusan atau notifikasi. Worker memakai least privilege dan lock/idempotensi per domain; hasil antrean tidak boleh menggandakan uang, periode, nomor, kursi atau notifikasi.

5.2 Kontrak API dan realtime

API memakai prefix /api/v1, validasi skema server, pagination serta error baku berupa code, message, field_errors dan request_id. OpenAPI 3.1 menghasilkan SDK Dart/TypeScript; skema bersama di TypeScript bukan pengganti kontrak Dart. Socket memiliki versi event, event_id, entity_id, timestamp dan payload minimum. Event dikirim sesudah commit dan bukan sumber kebenaran tunggal.

Domain	Kontrak minimum
Auth	register, OTP verify/resend, login/MFA, refresh, recovery, logout/all, sessions
Membership	profil sendiri, effective_status, kartu, renewal eligibility dan periode
Payments	buat instruksi, unggah/ganti bukti, detail/histori, antrean, approve/reject

Domain	Kontrak minimum
Events	daftar/detail, reserve, kirim bukti, tiket QR, peserta dan check-in
Content	feed/detail, like, banner, halaman serta CRUD admin
Network dan chat	direktori/profil, block/report, room/member, pesan/keyset, read/reaction
Notifications	inbox/read/preferences, register/unregister token, delivery admin berizin
Files dan account	upload/akses privat, reauth, deletion request/status dan web challenge
Public	verifikasi token KTA, konfigurasi legal, versi aplikasi minimum, status maintenance dan tautan aplikasi yang aman

Kode galat minimum: VALIDATION_ERROR, UNAUTHENTICATED, MFA_REQUIRED, FORBIDDEN, MEMBERSHIP_REQUIRED, ACCOUNT_SUSPENDED, OTP_EXPIRED, RATE_LIMITED, FILE_INVALID, PAYMENT_STATE_CONFLICT, PROOF_VERSION_CONFLICT, EVENT_SOLD_OUT, RESERVATION_EXPIRED, TICKET_ALREADY_CHECKED_IN, IDEMPOTENCY_CONFLICT, MAINTENANCE, INTERNAL_ERROR. Token/secret dan stack trace internal tidak dikirim ke klien. Setiap klien memetakan kode galat ke perilaku UI yang seragam melalui satu katalog penanganan galat.

Refresh Flutter dikoordinasikan satu proses pada satu perangkat agar request paralel tidak memakai token lama. Web admin memakai access token di memory dan refresh cookie HttpOnly, Secure serta SameSite sesuai deployment; karena itu domain admin dan API ditetapkan pada site yang sama melalui D12. HTTP mutasi berbasis cookie memeriksa Origin/CSRF. Token tidak disimpan di localStorage admin. Flutter memakai secure storage; logout menghapus cache KTA dan data akun privat. TTL refresh mobile/admin diputus D1, terpisah dari idle timeout.

5.3 Topologi lingkungan dan kapasitas

Dev menggunakan Docker Compose lokal. Staging dan production memiliki database, user DB, Redis namespace atau instance, volume berkas, secrets, domain dan proyek push yang terpisah. Jika memakai VPS yang sama, keduanya tetap berbagi failure domain; staging tidak boleh melakukan stress test yang mengganggu production. Data staging memakai data sintetis; data pribadi nyata tidak disalin ke staging.

VPS awal 4 vCPU, RAM 8 GB dan disk 100 GB di region Jakarta atau Singapura (*disahkan v3.5*); angka ini adalah titik awal, bukan kapasitas yang dijamin. Beban Coolify, PostgreSQL, Redis, API, worker, build dan monitor harus diukur pada Tahap 0. Usulan build image dijalankan CI agar kompilasi tidak menghabiskan RAM production. D7 menyetujui kapasitas berdasarkan N-01 sampai N-06.

Firewall membuka 80/443; SSH 22 dibatasi IP tepercaya/VPN dan memakai key. PostgreSQL serta Redis tidak diekspos publik. Coolify menggunakan subdomain terpisah, 2FA dan akses pengelola yang tercatat. Secrets berada di pengelola secrets/Coolify dan GitHub Secrets, tidak masuk source, image layer, log atau frontend.

5.4 Berkas dan perpindahan storage

StorageDriver menyediakan put, read/signed access, delete, stat dan copy. Metadata object_key tidak berisi nama/email pengguna. Berkas privat dilayani setelah pemeriksaan izin; token URL maksimal 10 menit terikat file dan tujuan. TTL tidak menggantikan otorisasi. Cache publik tidak boleh menyimpan bukti, chat atau ekspor. Avatar publik hanya disediakan sesuai kebijakan visibilitas.

Usulan pemicu perpindahan ke S3-compatible: disk > 60 persen atau berkas > 20 GB, disertai proyeksi pertumbuhan. Alert disk warning 60 persen, critical 80 persen. Perpindahan tidak selesai hanya dengan

mengganti STORAGE_DRIVER: salin dan cocokkan checksum, perbarui lokasi per file, pertahankan fallback read selama transisi, lalu hapus salinan lama sesudah verifikasi dan backup. D9 menetapkan ambang, provider dan jadwal.

5.5 Deployment, backup dan insiden

Push main yang lolos CI membangun staging; tag versi yang disetujui gerbang rilis mempromosikan image yang sama ke production. Migrasi skema (perubahan struktur database yang terversi) dijalankan oleh job deployment tunggal dengan lock, bukan setiap startup replica API/worker. Perubahan skema memakai strategi kompatibel saat memungkinkan; rollback image tidak otomatis membalik perubahan skema atau data.

Backup DB dan berkas harian terenkripsi disimpan di luar VPS, retensi awal usulan 30 hari. Manifest menghubungkan dump DB, manifest/checksum berkas, waktu, schema version, image version dan deletion ledger. Backup harus konsisten terhadap rujukan DB/berkas; snapshot filesystem atau mekanisme jeda mutasi dipakai saat konsistensi tidak dapat dijamin. Kunci backup disimpan terpisah dari salinan backup.

Restore bulanan dilakukan ke lingkungan bersih, lalu memeriksa login/MFA, anggota, total uang, tiket, chat, berkas dan penghapusan terdahulu. Redis cache/queue dibangun ulang dari state durable/outbox. Monitoring wajib meliputi HTTP, koneksi WS, DB, disk, umur backup, umur job/outbox tertua dan kegagalan provider. Panel Coolify down tidak boleh menghilangkan runbook Compose cadangan.

Usulan pembagian operasi: pengelola infra menangani alert dan restore; Super Admin menangani keputusan bisnis dan komunikasi layanan; pengembang menangani perbaikan aplikasi; QA memastikan regresi. Nama pemegang peran serta kanal eskalasi disahkan D9 sebelum go-live. Log diagnostik memiliki retensi usulan 30 hari tanpa PII; akses dan ekspor dibatasi.

6 Rancangan domain dan database

6.1 Konvensi dan inventaris

PostgreSQL 17 menggunakan skema app. Primary key entitas umumnya UUID; tabel relasi boleh memakai key komposit dan tabel pengaturan memakai key teks. UUID v7 dibuat di API/library yang diuji, karena generator bawaan PostgreSQL 17 menghasilkan v4 [R3]. Timestamp memakai timestamptz; nominal IDR menggunakan numeric(14,2), validasi >= 0 dan pembulatan server yang konsisten. Tidak memakai floating point untuk uang.

Model data terdiri atas 30 tabel inti (6.2) dan 7 tabel pendukung (6.3), total 37 tabel, serta 1 sequence. Seluruhnya dibangun sejak migrasi skema awal. DDL final serta indeks dikunci pada Tahap 0. Jumlah tabel bukan acceptance criterion produk; invarian dan traceability datanya yang wajib lulus.

6.2 Tabel inti

Domain	Tabel	Data dan aturan utama
Identitas	users	Email normalized unik, password_hash, status akun, email_verified_at, policy acceptance, session_version; tanpa NIK
Identitas	otp_codes	Purpose, challenge, hash/HMAC, expiry, attempts, consumed_at; konsumsi sekali
Identitas	sessions	Refresh hash, family_id, audience/device, MFA level, idle/expiry, revoked/replaced_by
Identitas	mfa_totp	Secret terenkripsi, verified_at, backup code hash; akses sangat terbatas
Identitas	admins	user_id unik, role, izin, status, relasi identitas pengurus; jaga Super Admin terakhir
Keanggotaan	alumni	Profil minimum, jenis kelamin, angkatan, kelas masuk/keluar, nomor urut N unik dan nomor lengkap AA.SS.JK.N unik, starts_at/expires_at, moderasi, privasi
Keanggotaan	master_professions	Nama/ID profesi dan status aktif; tidak menghapus master yang dipakai
Keanggotaan	master_skills	Nama/ID keahlian dan status aktif; konsisten dengan filter
Keuangan	payments	Pemilik nullable setelah deletion, jenis, snapshot nilai/metode, ticket_id bila terkait, proof_version, keputusan
Keuangan	payment_events	Riwayat status dan bukti, aktor, alasan, waktu serta versi; append-only
Keuangan	payment_methods	Bank/ewallet, provider, tujuan rekening dan pemilik, aktif/urutan; snapshot pada payment
Konfigurasi	app_settings	Biaya, periode, jendela, kebijakan, versi aplikasi minimum, status maintenance, schema value dan version
Konten	posts	Judul, slug unik, body tersanitasi, cover, kategori, status dan jadwal
Konten	post_likes	Key post_id+user_id; penghitung like konsisten
Konten	banners	Media, target, urutan, mulai/selesai; target tervalidasi
Konten	pages	Slug, judul, body, version/published_at untuk halaman legal

Domain	Tabel	Data dan aturan utama
Event	events	Mulai/selesai/zona waktu, jendela daftar/check-in, harga/kuota/status; tidak dihapus bila bertiket
Event	tickets	Satu tiket per anggota/event (1 kursi), total snapshot, status, hold_expires_at, kode QR unik, checked_in_at/by dan versi
Komunitas	blocks	Key blocker_id+blocked_id; larangan memblokir diri sendiri
Komunitas	rooms	Direct/group, direct_key unik, metadata grup dan last_message_at
Komunitas	room_members	Key room_id+user_id, role, status join/leave, read cursor dan mute
Komunitas	messages	Room/sender, client_message_id, teks/gambar/system, reply, waktu, deleted_at
Komunitas	message_reactions	Key message_id+user_id+emoji; akses room tetap diperiksa
Komunitas	reports	Pelapor/target/pesan, bukti minimum, kategori, status, tindakan dan penyelesaian
Notifikasi	notifications	User, kategori, judul, data deep link aman, event/dedup key dan read_at
Notifikasi	notification_preferences	Preferensi kategori/kanal per user; keamanan wajib terpisah
Notifikasi	device_tokens	Platform/token unik, pemilik aktif, failure class, revoked_at; tidak dimasukkan log
Berkas	files	Pemilik, purpose, storage driver, object_key, MIME, byte/checksum, visibility, processing/deleted status
Audit	audit_logs	Aktor/tindakan/entitas, waktu, request_id, alasan, before/after tersaring; akses append-only aplikasi
Akun	account_deletions	Jenis, request/status, steps_done, last_error aman, batas/waktu selesai dan ledger pemulihan

Sequence membership_no_seq mengalokasikan nomor urut N global mulai dari 1. Gap karena transaksi batal diterima; urutan tidak harus tanpa celah. Nomor lengkap disimpan bersama segmen pembentuknya dan dihitung ulang hanya melalui koreksi admin yang diaudit.

6.3 Tabel pendukung

Tabel	Kebutuhan yang dipenuhi
alumni_professions	Relasi alumni dan master_professions dengan FK serta key pasangan unik
alumni_skills	Relasi alumni dan master_skills dengan FK serta key pasangan unik
membership_events	Histori aktivasi/renewal/suspend/unsuspend, sebelum/sesudah periode dan payment sumber
outbox_events	Peristiwa durable dalam transaksi bisnis, dedup key, dispatch status dan attempts
notification_deliveries	Hasil per kanal/perangkat, provider status, attempt, next_retry dan error class
idempotency_keys	Scope aktor/endpoint/key, payload hash, hasil, status dan expiry

Tabel	Kebutuhan yang dipenuhi
payment_adjustments	Koreksi/refund administratif bertaut payment, nominal, alasan, aktor dan bukti minimum

Status payment tetap merekam paid historis; refund mempunyai catatan penyesuaian dan status penyelesaian sendiri.

6.4 Hubungan inti dan invarian

Users memiliki satu profil alumni atau identitas admin terpisah sesuai provisioning. Users memiliki banyak sessions, payments, notifications dan membership_events. Payments registration/renewal menghasilkan membership_events; payments ticket mengacu tickets. Events mempunyai banyak tickets; satu tiket mewakili satu anggota. Rooms mempunyai banyak room_members dan messages. Files direferensikan avatar, cover, bukti serta pesan dengan purpose yang sesuai.

- Nomor urut N unik global dan tidak pernah dipakai ulang; nomor lengkap AA.SS.JK.N juga unik. Satu aktivasi/renewal per payment paid dijaga key unik pada histori membership.
- Partial unique index untuk payment pending per user/type berlaku hanya registration/renewal. Ticket payments unik per tiket, bukan per user/type, agar orang dapat memesan event berbeda.
- Partial unique index tickets(user_id,event_id) berlaku pada awaiting_payment, awaiting_review dan paid. Tiket cancelled/expired boleh dibuat ulang; akun yang telah dihapus tidak menghambat pengguna lain.
- Reservasi, approval, expiry dan cancellation mengunci tiket/event dalam urutan konsisten. Hitung ulang atau counter yang dijaga transaksi harus memenuhi 0 <= available <= total.
- Kode QR tiket unik; update check-in memakai syarat checked_in_at IS NULL dan status paid dalam transaksi. Scan ulang mengembalikan catatan sebelumnya.
- Like, reaksi, room direct, client_message_id dan event dedup mempunyai constraint unik yang sesuai.
- Kolom keanggotaan/uang/izin tidak dapat diperbarui langsung lewat endpoint profil umum. DB grants serta transaksi domain menguatkan batas service.
- Actor audit tidak hanya berasal dari input pengguna. Set context transaksi dari identitas server; trigger dan application audit memakai correlation key agar tidak menggandakan catatan.

6.5 Indeks, transaksi dan penghapusan

Indeks FK dipasang bila digunakan join/delete/referential checks; indeks status dipadukan dengan waktu/owner sesuai pola query, bukan menambah setiap kolom tanpa bukti. Indeks prioritas: payments(status,submitted_at), tickets(event_id,status), messages(room_id,created_at,id), notifications(user_id,created_at,id), reports(status,created_at), audit_logs(entity_type,entity_id,created_at), dan outbox_events(status,next_attempt_at). Query plan diuji pada data N-04.

Foreign key ke users yang diperlukan untuk keuangan dan audit dapat SET NULL saat penghapusan, tetapi snapshot identitas tetap harus dibersihkan. Entitas profil dan konten buatan pengguna mengikuti F-14. Soft delete tidak cukup untuk memenuhi penghapusan akun; purge fisik/anonimisasi dan cleanup berkas dijalankan. Sesuai D2, tidak ada data pribadi yang ditahan setelah penghapusan; catatan keuangan, laporan dan audit yang tersisa sudah dianonimkan.

Seed data dev dan staging memakai fixture sintetis yang ditandai jelas dan tidak pernah dijalankan pada production. Tidak ada trigger yang boleh menimpa keputusan moderasi ketika payment berubah. Uji transaksi menggunakan request bersamaan dan injection failure sesudah setiap langkah kritis.

7 Stack teknologi dan struktur pekerjaan

7.1 Pilihan teknologi

Nomor mayor di bawah adalah baseline, bukan klaim versi terbaru. Pin versi patch, image digest, lockfile, runtime dan kompatibilitas dilakukan pada Tahap 0. Upgrade mayor memerlukan ADR, build klien, uji kontrak dan regresi; tidak otomatis mengganti framework karena tersedia versi baru.

Lapisan	Baseline	Ketentuan
Aplikasi anggota	Flutter 3.x, Dart, Riverpod, secure storage, klien Socket.IO	Android/iOS; dibangun baru mengikuti Guidelines KAPDH v1.0; SDK dari OpenAPI
Web admin	React 19, TypeScript 5, Vite 8, TanStack Query/Router/Table	Tabel server-side; Tailwind 4, shadcn/ui, react-hook-form dan validasi zod; token desain diselaraskan dengan Flutter
Situs publik	Astro static	Shell KTA/delete-account memanggil API; route fallback untuk URL dinamis diuji
API	NestJS 11 dengan Fastify adapter	Modul domain, guards, OpenAPI 3.1, REST dan socket terotorisasi
Database	PostgreSQL 17, Drizzle, migrasi skema SQL versioned	Constraint/invarian diuji; migrasi skema job tunggal; UUID v7 di aplikasi
Auth	Bcrypt, OTP email, JWT/refresh, TOTP	Cost bcrypt dikalibrasi; rahasia di backend
Job dan realtime	Redis, BullMQ, Socket.IO Redis adapter	Outbox durable, dedup, retries dan replay dari DB
Storage	Volume /data/files dan StorageDriver	Local awal; S3-compatible setelah perpindahan terverifikasi
Email dan push	Provider transaksional dipilih D10; FCM/APNs	Push wajib R1.0; delivery status dan retry tersedia
Proxy dan deploy	Coolify, Traefik, TLS, Docker image dari CI	Database/Redis privat; staging dan production terpisah
Backup	Backup PostgreSQL dan restic/rclone terenkripsi	Di luar VPS; restore bulanan dan manifest konsisten
Observabilitas	Log terstruktur, error tracking dan monitor uptime	GlitchTip/Uptime Kuma kandidat; penempatan menyesuaikan kapasitas
CI	GitHub Actions, lockfile, pemeriksaan dependensi	Lint/typecheck/test/build/contract gates; secrets tidak masuk repo

7.2 Struktur repository

Backend dan web berada pada monorepo; Flutter berada di repository tersendiri. SDK Dart dibangkitkan dari packages/contracts dan didistribusikan ke repository Flutter melalui dependensi git bertag versi (atau registry privat), sehingga versi kontrak yang dipakai klien selalu tercatat.

Path	Tanggung jawab
apps/api	Modul NestJS, REST, guards dan gateway realtime
apps/worker	Dispatcher outbox, BullMQ, reminder, cleanup, ekspor dan deletion
apps/admin	React portal pengurus
apps/web	Astro situs publik dan shell verifikasi/penghapusan
packages/shared	Tipe/skema TypeScript, enum domain dan kode error
packages/contracts	OpenAPI, event schemas, generator serta SDK terbangkit
packages/database	Schema Drizzle, migrasi skema SQL, seed dan constraint
packages/storage	StorageDriver local/S3 dan kontrol metadata
packages/config	Environment validation dan konfigurasi bersama
packages/design-tokens	Token warna (hijau #215E1E, hijau gelap #0E280C, kuning emas, krem #FCF8F5), tipografi (Telegraf untuk judul, Poppins untuk isi), spasi dan radius dari Guidelines KAPDH; diekspor ke Tailwind dan tema Flutter. Lisensi Telegraf untuk aplikasi diverifikasi sebelum dipakai
docs	PRD, ADR, spesifikasi API, runbook deploy/backup/restore dan bukti QA
infra	Dockerfiles, Compose cadangan, konfigurasi deploy serta backup

Boundary: frontend tidak mengimpor database, provider secrets atau kode worker. Aturan bisnis berada di service API dan transaksi domain. Worker menggunakan domain commands yang idempoten. Modul tidak mengubah tabel modul lain melalui shortcut tanpa kontrak. TypeScript strict, formatter, lint dan validasi env wajib. API client Flutter dan admin diperbarui bersama kontrak.

7.3 Panduan untuk pengembang dan AI agent

Implementasikan satu irisan vertikal per tugas: endpoint, aturan domain, constraint/migrasi skema, UI yang diperlukan, error states, serta verifikasi acceptance criteria. Cantumkan ID F/N/AC pada tugas dan laporan perubahan. Jangan mengklaim lulus dari mock data atau screenshot saja. UI mengikuti Guidelines KAPDH v1.0 dan prototipe yang disahkan; komponen baru ditambahkan ke design system, bukan dibuat ad hoc per layar.

Agent tidak boleh memindahkan business rules ke klien, menampilkan secret, menambahkan NIK, mengganti status paid tanpa adjustment, menonaktifkan MFA produksi, atau menyederhanakan kuota hanya dengan read-then-write tanpa transaksi. Jangan menambahkan Supabase, Firebase Auth/Firestore, atau backend-as-a-service lain sebagai pengganti modul API. Nilai yang belum diputus disediakan melalui konfigurasi, memakai fixture yang jelas pada dev, dan dilarang masuk production sebagai nominal rekaan.

8 Rencana pembangunan dan go-live

8.1 Tahapan dan gerbang milestone

Estimasi berikut disetujui pemilik produk sebagai dasar perencanaan (*v3.2*) untuk satu pengembang penuh waktu dibantu agent, belum termasuk masa stabilisasi sesudah go-live. Dibanding v3.0, pekerjaan migrasi data dan cutover dihapus, tetapi aplikasi Flutter kini dibangun dari nol sehingga Tahap 1 sampai 3 bertambah. Angka ini adalah rentang perencanaan, bukan tanggal rilis pasti; estimasi diukur ulang sesudah peta layar, prototipe dan backlog ber-ID selesai pada Tahap 0. Pekerjaan Flutter/admin dikerjakan dalam irisan kontrak yang sama; kapasitas satu pengembang tidak dihitung dua kali sebagai dua tim paralel.

Tahap	Estimasi	Hasil wajib dan gerbang keluar
0 Fondasi	3 sampai 4 minggu	Keputusan arsitektur terkunci, repo/CI, lingkungan, design tokens dari Guidelines KAPDH v1.0 dan prototipe layar yang belum ada, OpenAPI P0/P1, schema, auth/MFA, berkas, audit, outbox dan backup/restore dasar
1 Keanggotaan	5 sampai 6 minggu	Daftar/OTP, profil, iuran/review, periode, KTA/QR publik, push/inbox/email dan deletion, termasuk layar Flutter dan admin terkait; AC terkait lulus staging
2 Konten dan event	4 sampai 5 minggu	Berita/banner/legal, event/reservasi/paid/check-in, admin terkait dan aturan refund yang disahkan
3 Jejaring dan chat	5 sampai 6 minggu	Direktori/privasi, direct/grup, realtime, blokir, moderasi, reconnect dan kontrol hak yang lulus
4 Kesiapan rilis	2 sampai 3 minggu	E2E/security/load/restore, inisialisasi produksi (8.2), review dan rilis toko aplikasi, go-live (8.3) dan sign-off
Stabilisasi	2 sampai 4 minggu tambahan	Pemantauan, penanganan insiden, perbaikan prioritas dan baseline metrik 30 hari

Total 19 sampai 24 minggu sebelum stabilisasi. Urutan ini mengharuskan fondasi auth, izin, berkas, audit dan outbox selesai sebelum modul bisnis. Chat tidak dibuka sebelum blokir/pelaporan/moderasi siap. Event paid tidak dibuka sebelum reservasi, review, check-in dan proses pembatalan diuji. Jadwal app-store review, provisioning domain, email dan akun developer toko merupakan dependensi yang dapat memengaruhi tanggal.

8.2 Inisialisasi lingkungan produksi

Karena tidak ada data yang dipindahkan, production dimulai dari database kosong. Inisialisasi berikut dijalankan dengan skrip yang dapat diulang, diuji lebih dahulu pada staging, dan tercatat pada audit.

1. **Infrastruktur.** Provisioning VPS, Coolify, domain dan DNS (D12), TLS, secrets, firewall, tujuan backup di luar VPS, dan monitoring. Backup dan restore dari database kosong dibuktikan sebelum data pengguna pertama masuk.
2. **Skema.** Job deployment menjalankan migrasi skema awal sampai versi rilis. Tidak ada data seed dev atau fixture sintetis yang dijalankan pada production.
3. **Bootstrap Super Admin.** Super Admin pertama dibuat melalui perintah CLI sekali pakai di server (bukan endpoint publik) yang menolak berjalan bila Super Admin aktif sudah ada. Akun wajib mengganti sandi awal dan mendaftarkan TOTP sebelum aktif. Minimal dua Super Admin aktif sebelum go-live; pemegangnya ditetapkan D1.

4. **Data referensi.** Master profesi dan keahlian, metode bayar, app_settings (nominal D4, periode, jendela renewal, versi aplikasi minimum), halaman legal (privasi, ketentuan, ketentuan komunitas, bantuan), dan kontak dukungan. Nilai yang belum disahkan memblokir go-live.
5. **Layanan eksternal.** Proyek FCM/APNs production, domain email dengan SPF/DKIM/DMARC, serta provider email transaksional (D10).
6. **Toko aplikasi.** Akun Apple Developer Program dan Google Play Console atas nama organisasi (memerlukan nomor D-U-N-S), signing key, listing, URL kebijakan privasi, formulir keamanan data, URL /delete-account, kontak moderasi, dan akun demo terverifikasi untuk reviewer agar fitur anggota aktif dapat diuji (D16).
7. **Gladi.** Seluruh langkah di atas dijalankan dari nol pada staging, dilanjutkan smoke test semua peran dan restore ke lingkungan bersih.

8.3 Go-live

D16 menetapkan jadwal go-live dan strategi rilis toko aplikasi. Urutan yang disarankan:

1. Bekukan tag versi image, SDK dan build Flutter yang lulus gerbang rilis (9.3).
2. Jalankan inisialisasi produksi (8.2) dan verifikasi backup pertama yang dapat direstore.
3. Jalankan smoke test production dengan akun uji: login/MFA, payment/period, kartu/public verify, tiket/scan, chat, file, push dan deletion. Data uji dihapus melalui alur penghapusan resmi atau ditandai dan dikecualikan dari metrik. Pengurus serta QA menandatangani bukti gerbang.
4. Kirim build Flutter ke review toko aplikasi terhadap backend production yang sudah aktif, karena reviewer memerlukan layanan yang berfungsi. Pendaftaran boleh terbuka, tetapi pengumuman ke alumni menunggu persetujuan toko.
5. Rilis aplikasi secara bertahap (staged rollout di Google Play, phased release di App Store), buka web admin untuk pengurus, lalu umumkan ke alumni melalui grup WhatsApp alumni, situs kapdh.or.id dan media sosial resmi. Kanal dukungan awal: bantuan@kapdh.or.id dan satu nomor WhatsApp admin.
6. Pantau metrik kesehatan dan antrean pembayaran secara ketat selama minggu pertama.

8.4 Rollback dan pemulihan setelah go-live

Titik kegagalan	Tindakan yang diperbolehkan
Gagal sebelum ada data pengguna nyata	Hentikan layanan, perbaiki, reset lingkungan production secara terkontrol, lalu jalankan ulang inisialisasi
Bug kritis setelah ada data pengguna	Forward-fix dan hotfix; mode maintenance read-only bila integritas data terancam. Rilis Flutter perbaikan dan naikkan versi minimum hanya setelah versi baru dapat diunduh
Perubahan skema tidak kompatibel dengan image sebelumnya	Jangan menganggap rollback image memulihkan skema; gunakan runbook kompatibilitas/restore dan pertimbangkan RPO nyata
Data/berkas hilang atau rusak	Restore DB+berkas dengan manifest yang sama, terapkan deletion ledger dan replay outbox, lalu periksa konsistensi sebelum dibuka

Kegagalan login, salah status/nominal, paparan file privat, oversell, gagal MFA, atau konfigurasi produksi yang belum disahkan merupakan alasan menunda go-live. Restore dari backup setelah ada transaksi baru dapat menghilangkan data sesudah titik backup sehingga memerlukan pemeriksaan dan komunikasi kepada pengguna terdampak.

9 Pengujian dan penerimaan rilis

9.1 Matriks keterlacakan

Semua F-01 sampai F-17 serta N-01 sampai N-16 harus memiliki bukti uji pada versi image, schema dan klien tertentu. Tabel ini menunjukkan kelompok UAT minimum; acceptance criteria rinci tetap ada pada bagian 3.

UAT	Cakupan	Bukti yang diperlukan
U-01 Identitas	F-01, F-02, F-16; N-07, N-08	OTP expiry/replay/rate limit; refresh reuse; MFA; idle; reset; izin dan Super Admin terakhir
U-02 Iuran	F-03, F-04, F-07	Approve/reject/resubmit; bukti versi sebelumnya; double approval; periode kalender; suspend tidak terhapus
U-03 Kartu	F-05, F-06	Cache 7 hari, logout/expiry, signature tamper, status online terkini, data minimum dan API down
U-04 Konten	F-08, F-15	Draft/jadwal/arsip, sanitize, banner, like idempoten dan CRUD berizin
U-05 Event	F-09	Race kuota, satu tiket per anggota/event, hold expiry, review, gratis, QR tiket, double scan, cancel/refund
U-06 Jejaring	F-10, F-12	Search/filter/paging, hidden fields tidak pada payload, block dua arah, report/unsuspend
U-07 Chat	F-11, F-12; N-02	Room unik, socket auth, retry/reconnect, order pesan, unread, file privat dan pencabutan hak
U-08 Notifikasi	F-13	Inbox/outbox, preferensi, deep link, gagal provider, token ganti akun dan pengingat dedup
U-09 Data pribadi	F-14; N-09, N-10, N-15	Deletion parsial/retry, anonimisasi snapshot/log, konten user, web request dan restore ledger
U-10 Pengurus	F-15, F-16, F-17	Setiap izin positif/negatif, version conflict, conflict of interest dan ekspor CSV aman
U-11 Operasi	N-01 sampai N-06; N-14	Laporan load/realtime, backup/restore dan RPO/RTO, observabilitas serta alert
U-12 Inisialisasi produksi	Bagian 8.2 dan 8.3	Deploy dari nol, bootstrap Super Admin sekali pakai, seed referensi tanpa fixture dev, konfigurasi tersahkan, akun reviewer toko, restore dari backup pertama
U-13 Klien	N-03, N-11, N-12, N-13	Perangkat/browser sasaran, keyboard/semantics/text scaling, kontrak, deep link, wajib update dan maintenance

9.2 Skenario kritis yang wajib lulus

- Dua pengguna meminta kursi terakhir bersamaan; hanya kapasitas valid yang mendapat tiket. Satu anggota yang mengirim dua request bersamaan hanya mendapat satu tiket.
- Dua admin menyetujui bukti yang sama; hanya satu periode atau tiket aktif tercipta.
- Bukti diganti saat admin membaca; keputusan memakai versi sebelumnya ditolak.

- Worker mati setelah commit payment; saat pulih, kartu/tiket tetap benar dan outbox mengirim hasil sekali ke inbox.
- JWT/socket yang sudah dicabut digunakan sesudah logout-all, suspend atau pencabutan izin; tindakan terlindungi ditolak.
- Pengguna mengganti object ID untuk mengunduh bukti, gambar chat, profil privat atau audit pihak lain; tidak ada paparan data.
- Job renewal/reminder/release kursi dijalankan ulang; tidak memperpanjang periode atau mengembalikan kursi dua kali.
- Akun dihapus lalu backup direstore; data terhapus tidak aktif kembali dan total keuangan tetap cocok.
- Production dideploy dengan konfigurasi yang belum disahkan (nominal kosong, fixture dev, atau tanpa Super Admin ber-TOTP); gerbang menolak go-live.
- Pengurus mencoba menonaktifkan dua Super Admin bersamaan hingga tidak tersisa; transaksi mencegah keadaan tanpa pengurus utama.

9.3 Gerbang go-live

R1.0 diterima bila seluruh AC wajib lulus pada staging yang menyerupai target, tidak ada bug kritis/tinggi yang mengganggu identitas, uang, kuota, data privat atau akses admin, serta target N yang disahkan terbukti. Kekurangan minor memiliki owner dan jadwal tindak lanjut yang disetujui; tidak dipakai untuk mengecualikan kebutuhan keamanan atau integritas data.

Paket penerimaan berisi build Flutter Android/iOS, image API/worker/web, OpenAPI dan SDK, schema/migrasi skema, runbook deploy/backup/restore/inisialisasi/rollback, laporan UAT/load/security/restore, halaman legal/delete-account, akun pengurus dengan MFA, serta daftar dependensi dan pemegang akses. Penghapusan akun, UGC moderation dan klasifikasi kanal iuran pada toko aplikasi diperiksa terhadap [R1], [R2], [R6] dan [R7].

Pemilik produk menyetujui cakupan dan kebijakan; bendahara menyetujui konfigurasi biaya dan metode bayar; QA menyetujui hasil UAT; pengelola infra menyetujui restore dan operasional. Tidak ada sign-off yang dianggap telah diberikan dalam dokumen ini. Setiap perubahan kebutuhan setelah persetujuan mencatat ID, alasan, dampak pada AC/data/jadwal dan versi PRD baru.

10 Keputusan terbuka dan risiko

10.1 Register keputusan

Dokumen dapat ditinjau sekarang. Keputusan bertanda gerbang harus ditutup sebelum tahap yang disebut. Owner pada tabel adalah fungsi penanggung jawab, bukan penetapan nama personel yang belum diberikan. ID keputusan tidak dipakai ulang.

ID	Keputusan yang harus disahkan	Owner dan gerbang
D1	**Disahkan v3.5.** Super Admin pertama: Bayu Musthafa; Super Admin kedua ditunjuk sebelum go-live. Bootstrap/MFA/recovery mengikuti 8.2; tanpa akses admin aal1 production. Sisa teknis: TTL refresh dan nilai rate limit final	Pemilik produk; sisa teknis oleh pengembang akhir Tahap 0
D2	**Ditutup v3.2.** Tanpa NIK dan tanpa periode retensi data pribadi. Saat akun dihapus, data pribadi dan file bukti transfer dihapus; catatan keuangan, tiket, laporan dan audit tersisa dalam bentuk anonim. Backup berotasi 30 hari dengan deletion ledger.	Pemilik produk; selesai
D3	**Ditutup v3.4.** Format AA.SS.JK.N, kode status pendidikan, rumus tahun akademik, koreksi oleh admin, dan kode angkatan KTA ditetapkan pada 3.5. *Disahkan v3.3:* field pendaftaran dan isi KTA mengikuti guidelines tanpa Nomor KTP. *Disahkan v3.2:* anggota yang sudah ada mendaftar ulang; tanpa impor massal	Pemilik produk; selesai
D4	**Ditutup v3.3.** Nominal dikelola di web admin; nilai awal register Rp50.000, pembuatan KTA Rp10.000, perpanjangan Rp10.000/tahun; KTA fisik tidak termasuk R1.0. *Disahkan v3.2:* periode 12 bulan dari approved_at, expiring 30 hari, jendela renewal 30 hari, tanpa masa tenggang	Pemilik produk; selesai
D5	**Ditutup v3.5.** Hold 24 jam, eskalasi review 2 hari kerja, check-in 2 jam sebelum acara sampai selesai; undangan grup oleh admin grup dan histori sejak bergabung sebagai default. *Disahkan v3.2:* satu tiket per anggota per event; chat 4.000 karakter dan grup 100 anggota	Pemilik produk; selesai
D6	**Ditutup v3.5.** Aturan pembatalan dan refund manual pada 3.9: refund penuh bila event dibatalkan, pembatalan peserta sampai H-3, bendahara memproses paling lambat 7 hari kerja	Pemilik produk; selesai
D7	**Disahkan v3.5.** VPS 4 vCPU, RAM 8 GB, disk 100 GB, Jakarta atau Singapura; Android 8.0+, iOS 15+; dua versi terakhir Chrome, Edge, Firefox, Safari. Sisa teknis: pin versi runtime dan konfirmasi kapasitas melalui uji beban	Pengembang dan infra; akhir Tahap 0
D8	Baseline/target produk, SLA review/moderasi/deletion, SLO dan kondisi pengukuran	Pemilik dan pengurus; sebelum sign-off rilis
D9	**Disahkan v3.5.** Akses root/Coolify: pemilik produk dan satu cadangan (SSH key, 2FA). Backup harian terenkripsi ke object storage di luar VPS (misalnya Cloudflare R2, Backblaze B2 atau penyedia VPS); kunci backup di password manager dan satu salinan cetak terpisah; alert Uptime Kuma ke Telegram/WhatsApp/email; uji restore bulanan. Ambang S3 mengikuti 5.4	Infra dan pemilik; backup siap akhir Tahap 0

ID	Keputusan yang harus disahkan	Owner dan gerbang
D10	**Disahkan v3.5.** Pengirim noreply@kapdh.or.id dengan SPF, DKIM dan DMARC; provider dipilih pengembang dari Amazon SES, Brevo, Mailgun, Resend atau Postmark. Push melalui FCM dan APNs. Apple Developer Program (USD 99 per tahun) dan Google Play Console (USD 25 sekali) atas nama organisasi dengan D-U-N-S	Pemilik (akun dan anggaran) dan pengembang (provider); sebelum Tahap 1
D11	**Dihapus pada v3.1.** Strategi cutover, versi jembatan dan penghentian vendor tidak berlaku untuk fresh development; rencana go-live dipindahkan ke D16.	Tidak berlaku
D12	**Ditutup v3.5.** Domain kapdh.or.id sudah dimiliki. kapdh.or.id (dan www) untuk situs publik, admin.kapdh.or.id untuk web admin, api.kapdh.or.id untuk API; staging memakai subdomain terpisah seperti staging-admin dan staging-api	Pemilik produk; selesai
D13	**Ditutup v3.5 dengan risiko tercatat.** Pembayaran iuran dan tiket memakai kanal sendiri (transfer manual) di luar sistem pembayaran toko	Pemilik produk; diperiksa ulang saat submit
D14	**Ditutup 11 Oktober 2026.** Pemilik produk menetapkan arsitektur API sendiri sebagai fresh development tanpa Supabase/Vercel; tidak ada alternatif Supabase self-hosted.	Pemilik produk; selesai
D15	**Ditutup v3.3.** Identitas visual dan acuan UI mengikuti Guidelines KAPDH Platform v1.0 [R8]. Tindak lanjut teknis: verifikasi lisensi font Telegraf dan prototipe layar yang belum tercakup guidelines.	Pemilik produk; selesai
D16	**Ditutup v3.5.** Target go-live setelah Idulfitri 2027 (akhir Maret sampai April 2027), diukur ulang mengikuti progres tahap; uji terbatas 2 sampai 3 minggu dengan pengurus dan 10 sampai 20 alumni (TestFlight dan closed testing); rilis bertahap; akun demo reviewer aktif dan belum bayar; pengumuman dan kanal dukungan pada 8.3	Pemilik produk; selesai

D13 ditutup dengan keputusan pemilik produk: iuran adalah kewajiban keanggotaan organisasi di dunia nyata dan tiket adalah layanan yang dinikmati di luar aplikasi, sehingga keduanya dibayar melalui kanal sendiri. Google Play mengecualikan layanan fisik seperti keanggotaan gym dan tiket acara langsung [R7], dan Apple mengizinkan metode lain untuk layanan yang dikonsumsi di luar aplikasi (3.1.3(e)) [R6]. Risiko yang tersisa: Apple 3.1.1 mewajibkan in-app purchase bila pembayaran membuka fitur di dalam aplikasi. Mitigasinya: (1) iuran diposisikan dan ditulis sebagai iuran keanggotaan organisasi, tanpa istilah upgrade, premium atau buka fitur; (2) catatan reviewer dan akun demo menjelaskan alur iuran; (3) rencana cadangan untuk iOS bila ditolak, yaitu instruksi bayar tidak ditampilkan di aplikasi iOS dan status keanggotaan diaktifkan pengurus setelah verifikasi di luar aplikasi. Penilaian ini bukan jaminan hasil review, dan kebijakan toko diperiksa ulang saat aplikasi diajukan.

10.2 Risiko dan mitigasi

Risiko	Dampak	Mitigasi dan bukti
Satu VPS/disk gagal	Semua layanan dan berkas berhenti	Backup luar VPS, restore bersih, RPO/RTO dan penanggung jawab
RAM/build melebihi kandidat VPS	Latensi atau service mati	Build di CI, resource limits, uji beban dan upgrade bila target gagal

Risiko	Dampak	Mitigasi dan bukti
Pembangunan Flutter dari nol melebihi estimasi	Jadwal rilis bergeser	Design system dan prototipe di Tahap 0, irisan vertikal, pengukuran ulang estimasi per tahap
Layar di luar guidelines belum dirancang saat coding dimulai	Pengerjaan ulang layar	Prototipe layar tambahan di Tahap 0 dengan gaya guidelines; perubahan desain sesudahnya melalui change request
Kuota/approval race	Oversell atau aktivasi ganda	Locks/constraint, idempotensi dan uji konkurensi
Cache KTA dianggap status terkini	Kartu suspended terlihat aktif offline	Label/waktu sync, batas 7 hari dan verifikasi online untuk pembuktian
Snapshot/log/backup menyimpan PII	Deletion dan privasi tidak terpenuhi	Whitelist snapshot, redaksi, ledger restore dan kebijakan D2
Redis/provider gagal	Status atau notifikasi tertunda	Outbox DB, replay, retry terklasifikasi dan fallback inbox
Tidak ada pengurus pengganti	Pemulihan admin/approval terhambat	Akun terpisah, minimal dua Super Admin dan dua pengurus pembayaran, uji Super Admin terakhir dan recovery
Pembatalan berbayar tanpa prosedur	Sengketa peserta dan bendahara	D6, adjustment, notifikasi dan bukti penyelesaian
App store menolak bayar/UGC/deletion	Publikasi Flutter tertunda	D13 dengan positioning iuran organisasi, catatan reviewer, akun demo dan rencana cadangan iOS; halaman deletion, moderation/contact dan review sebelum publikasi
Reviewer toko tidak dapat menguji fitur anggota	Review ditolak atau berulang	Akun demo terverifikasi dan catatan reviewer (D16)
Konfigurasi produksi belum disahkan	Nominal atau legal rekaan tampil ke pengguna	Gerbang U-12 dan blokir go-live bila nilai belum disahkan

11 Lampiran dan rujukan

11.1 Glosarium

Istilah	Arti pada dokumen ini
KTA	Kartu tanda anggota digital; nomor dan masa berlaku keanggotaan
Nomor anggota	AA.SS.JK.N: angkatan, status pendidikan, jenis kelamin, dan nomor urut global
R1.0	Rilis lengkap pertama yang memuat seluruh F-01 sampai F-17
P0 P1 P2	Prioritas/urutan pembangunan; bukan izin mengeluarkan modul dari R1.0
Fresh development	Pembangunan dari awal tanpa sistem, data, atau klien lama yang harus dipertahankan
Paid	Dana diverifikasi pengurus, atau tiket gratis terkonfirmasi dengan nilai nol
Tiket	Pendaftaran satu anggota untuk dirinya sendiri pada satu event, dengan satu QR dan satu check-in
Effective status	Hasil status akun, periode keanggotaan dan lapisan moderasi untuk otorisasi
Outbox	Catatan event durable yang committed bersama perubahan bisnis
Idempotensi	Pengulangan operasi yang sama tidak menggandakan efek bisnis
Migrasi skema	Perubahan struktur database yang terversi dan dijalankan job deployment; bukan pemindahan data dari sistem lain
Bootstrap	Pembuatan Super Admin pertama melalui perintah server sekali pakai
Design system	Kumpulan token visual dan komponen UI yang dipakai bersama Flutter dan web admin
RPO RTO	Batas kehilangan waktu data dan target waktu memulihkan layanan
Go-live	Pembukaan layanan production kepada pengguna untuk pertama kali
ADR	Catatan keputusan arsitektur dengan alasan, tradeoff dan dampak

11.2 Rujukan

R0 adalah PRD KAPDH Apps v2, bertanggal 11 Oktober 2026, yang diberikan pemilik produk. R0 menjadi sumber fitur dan batasan teknologi; konteks production Supabase/Vercel dan rencana migrasi pada R0 tidak berlaku sejak v3.1. Rujukan resmi berikut diperiksa pada 11 Oktober 2026 untuk ketentuan tertentu; persyaratan kebijakan perlu diperiksa kembali ketika rilis diajukan.

- **R1 Apple account deletion.** Menyediakan penghapusan dalam aplikasi dan data terkait serta pengungkapan retensi yang berlaku. https://developer.apple.com/help/app-review/guideline-reference/5-1-1-account-deletion
- **R2 Google Play account deletion.** Jalur penghapusan dalam aplikasi dan resource web untuk permintaan tanpa memasang aplikasi. https://support.google.com/googleplay/android-developer/answer/13327111
- **R3 PostgreSQL 17 UUID functions.** Generator native gen_random_uuid menghasilkan UUID v4; UUID v7 dibuat di lapisan aplikasi yang diuji. https://www.postgresql.org/docs/17/functions-uuid.html
- **R4 Dihapus pada v3.1** (rujukan keamanan sandi Supabase untuk migrasi hash tidak lagi relevan).

- **R5 Firebase FCM error codes.** UNREGISTERED memerlukan penghentian token; gangguan sementara memakai retry/backoff. https://firebase.google.com/docs/cloud-messaging/error-codes
- **R6 Apple App Review Guidelines.** Moderasi UGC pada 1.2 serta klasifikasi pembayaran pada 3.1 menjadi pemeriksaan distribusi. https://developer.apple.com/app-store/review/guidelines/
- **R7 Google Play Payments policy.** Perbedaan fungsi/digital dan barang/layanan fisik perlu dinilai untuk kanal bayar sasaran. https://support.google.com/googleplay/android-developer/answer/9858738
- **R8 Guidelines KAPDH Platform v1.0.** Brand guideline dan mockup aplikasi anggota serta web manajemen data alumni yang diberikan pemilik produk pada 12 Oktober 2026. Bila guidelines berbeda dengan aturan PRD, keputusan pada register D berlaku.

Rujukan tidak menetapkan kebijakan retensi Indonesia atau nominal iuran. Periode, SLA, kapasitas dan pilihan administratif bertanda Usulan adalah keputusan produk yang belum disahkan, dan nilai bertanda disahkan v3.2 adalah keputusan pemilik produk, bukan fakta dari dokumentasi pihak ketiga.

11.3 Riwayat versi dan tindak lanjut

Versi	Tanggal	Perubahan
2	11 Oktober 2026	Dokumen sumber dengan fitur F-01 sampai F-17, target VPS/Coolify dan rencana migrasi
3.0	11 Oktober 2026	Penyempurnaan scope, AC, izin, siklus status, data, kontrak, operasi, QA, migrasi, keputusan dan rujukan
3.1	11 Oktober 2026	Ditetapkan sebagai fresh development tanpa Supabase/Vercel dan tanpa migrasi data. Migrasi/cutover diganti inisialisasi produksi dan go-live; estimasi diukur ulang; D11 dihapus, D14 ditutup, D15 dan D16 ditambahkan; U-12 diganti
3.2	12 Oktober 2026	Hasil tinjauan pemilik produk: perubahan v3.1 disetujui; aturan iuran, KTA offline, chat, sandi dan konflik kepentingan disahkan; satu tiket per anggota per event; moderasi Flutter dihapus; D2 ditutup tanpa periode retensi data pribadi
3.3	12 Oktober 2026	Diselaraskan dengan Guidelines KAPDH v1.0: D15 dan D4 ditutup, D3 sebagian disahkan; tanpa Nomor KTP; KTA dibuat Tidak Aktif saat pendaftaran; akun admin tetap terpisah
3.4	12 Oktober 2026	Format nomor anggota AA.SS.JK.N, kode status pendidikan, rumus tahun akademik dan aturan koreksi admin ditetapkan; D3 ditutup; AC F05-6 ditambahkan
3.5	12 Oktober 2026	D1, D7, D9, D10 disahkan; D5, D6, D12, D13, D16 ditutup; aturan refund event, jendela check-in, kapasitas VPS, domain dan rencana go-live ditetapkan

Seluruh keputusan produk telah disahkan. Tindak lanjut: pemilik produk mengurus D-U-N-S, akun toko aplikasi, email domain, VPS dan Super Admin kedua; pengembang mengunci sisa teknis D1 dan D7 serta memulai Tahap 0 dengan design tokens dari Guidelines KAPDH, prototipe layar tambahan, kontrak OpenAPI P0/P1 dan fondasi repository. Dokumen belum mengandung persetujuan deployment production.